



ANAQUA, INC.

SOC 2 REPORT

FOR

INTELLECTUAL ASSET MANAGEMENT SYSTEM

A TYPE 2 INDEPENDENT SERVICE AUDITOR'S REPORT ON
CONTROLS RELEVANT TO SECURITY

JULY 1, 2023, TO JUNE 30, 2024

Attestation and Compliance Services



Proprietary & Confidential

Unauthorized use, reproduction, or distribution of this report, in whole or in part, is strictly prohibited.

This report is intended solely for use by the management of Anaqua, Inc., user entities of Anaqua, Inc.'s services, and other parties who have sufficient knowledge and understanding of Anaqua, Inc.'s services covered by this report (each referred to herein as a "specified user").

If the report recipient is not a specified user (herein referred to as a "non-specified user"), use of this report is the non-specified user's sole responsibility and at the non-specified user's sole and exclusive risk. Non-specified users may not rely on this report and do not acquire any rights against Schellman & Company, LLC as a result of such access. Further, Schellman & Company, LLC does not assume any duties or obligations to any non-specified user who obtains this report and/or has access to it.

Unauthorized use, reproduction, or distribution of this report, in whole or in part, is strictly prohibited.

TABLE OF CONTENTS

SECTION 1	INDEPENDENT SERVICE AUDITOR'S REPORT	1
SECTION 2	MANAGEMENT'S ASSERTION	5
SECTION 3	DESCRIPTION OF THE SYSTEM	7
SECTION 4	TESTING MATRICES	21

SECTION I

INDEPENDENT SERVICE AUDITOR'S REPORT

INDEPENDENT SERVICE AUDITOR'S REPORT

To Anaqua, Inc.:

Scope

We have examined Anaqua, Inc.'s ("Anaqua" or the "service organization") accompanying description of its Intellectual Asset Management System, in Section 3, throughout the period July 1, 2023, to June 30, 2024, (the "description"), based on the criteria for a description of a service organization's system in DC section 200, *2018 Description Criteria for a Description of a Service Organization's System in a SOC 2® Report* (AICPA, *Description Criteria*) ("description criteria"), and the suitability of the design and operating effectiveness of controls stated in the description throughout the period July 1, 2023, to June 30, 2024, to provide reasonable assurance that Anaqua's service commitments and system requirements were achieved based on the trust services criteria relevant to security ("applicable trust services criteria") set forth in TSP section 100, *Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy* (AICPA, *Trust Services Criteria*).

Anaqua uses various subservice organizations for cloud hosting services. The description indicates that complementary subservice organization controls that are suitably designed and operating effectively are necessary, along with controls at Anaqua, to achieve Anaqua's service commitments and system requirements based on the applicable trust services criteria. The description presents Anaqua's controls, the applicable trust services criteria, and the types of complementary subservice organization controls assumed in the design of Anaqua's controls. The description does not disclose the actual controls at the subservice organizations. Our examination did not include the services provided by the subservice organizations, and we have not evaluated the suitability of the design or operating effectiveness of such complementary subservice organization controls.

Service Organization's Responsibilities

Anaqua is responsible for its service commitments and system requirements and for designing, implementing, and operating effective controls within the system to provide reasonable assurance that Anaqua's service commitments and system requirements were achieved. Anaqua has provided the accompanying assertion, in Section 2, ("assertion") about the description and the suitability of design and operating effectiveness of controls stated therein. Anaqua is also responsible for preparing the description and assertion, including the completeness, accuracy, and method of presentation of the description and assertion; providing the services covered by the description; selecting the applicable trust services criteria and stating the related controls in the description; and identifying the risks that threaten the achievement of the service organization's service commitments and system requirements.

Service Auditor's Responsibilities

Our responsibility is to express an opinion on the description and on the suitability of design and operating effectiveness of controls stated in the description based on our examination. Our examination was conducted in accordance with attestation standards established by the American Institute of Certified Public Accountants (AICPA). Those standards require that we plan and perform our examination to obtain reasonable assurance about whether, in all material respects, the description is presented in accordance with the description criteria and the controls stated therein were suitably designed and operated effectively to provide reasonable assurance that the service organization's service commitments and system requirements were achieved based on the applicable trust services criteria. We believe that the evidence we obtained is sufficient and appropriate to provide a reasonable basis for our opinion.

An examination of the description of a service organization's system and the suitability of the design and operating effectiveness of controls involves the following:

- Obtaining an understanding of the system and the service organization's service commitments and system requirements.
- Assessing the risks that the description is not presented in accordance with the description criteria and that controls were not suitably designed or did not operate effectively.

- Performing procedures to obtain evidence about whether the description is presented in accordance with the description criteria.
- Performing procedures to obtain evidence about whether controls stated in the description were suitably designed to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria.
- Testing the operating effectiveness of controls stated in the description to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria.
- Evaluating the overall presentation of the description.

Our examination also included performing such other procedures as we considered necessary in the circumstances.

Service Auditor's Independence

We are required to be independent and to meet our other ethical responsibilities in accordance with relevant ethical requirements relating to the engagement.

Inherent Limitations

The description is prepared to meet the common needs of a broad range of report users and may not, therefore, include every aspect of the system that individual users may consider important to meet their informational needs.

There are inherent limitations in the effectiveness of any system of internal control, including the possibility of human error and the circumvention of controls.

Because of their nature, controls may not always operate effectively to provide reasonable assurance that the service organization's service commitments and system requirements are achieved based on the applicable trust services criteria. Also, the projection to the future of any conclusions about the suitability of the design and operating effectiveness of controls is subject to the risk that controls may become inadequate because of changes in conditions or that the degree of compliance with the policies or procedures may deteriorate.

Description of Test of Controls

The specific controls we tested, and the nature, timing, and results of those tests are presented in Section 4 of our report titled "Testing Matrices."

Opinion

In our opinion, in all material respects:

- the description presents Anaqua's Intellectual Asset Management System that was designed and implemented throughout the period July 1, 2023, to June 30, 2024, in accordance with the description criteria;
- the controls stated in the description were suitably designed throughout the period July 1, 2023, to June 30, 2024, to provide reasonable assurance that Anaqua's service commitments and system requirements would be achieved based on the applicable trust services criteria, if its controls operated effectively throughout that period and if the subservice organizations applied the complementary controls assumed in the design of Anaqua's controls throughout that period; and
- the controls stated in the description operated effectively throughout the period July 1, 2023, to June 30, 2024, to provide reasonable assurance that Anaqua's service commitments and system requirements were achieved based on the applicable trust services criteria, if complementary subservice organization controls assumed in the design of Anaqua's controls operated effectively throughout that period.

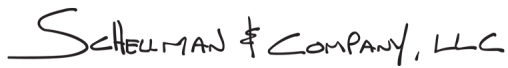
Restricted Use

This report, including the description of tests of controls and results thereof in Section 4, is intended solely for the information and use of Anaqua; user entities of Anaqua's Intellectual Asset Management System during some or all of the period of July 1, 2023, to June 30, 2024, business partners of Anaqua subject to risks arising from interactions with the Intellectual Asset Management System, practitioners providing services to such user entities

and business partners, prospective user entities and business partners, and regulators who have sufficient knowledge and understanding of the following:

- the nature of the service provided by the service organization;
- how the service organization's system interacts with user entities, business partners, subservice organizations, and other parties;
- internal control and its limitations;
- complementary subservice organization controls and how those controls interact with the controls at the service organization to achieve the service organization's service commitments and system requirements;
- user entity responsibilities and how they may affect the user entity's ability to effectively use the service organization's services;
- the applicable trust services criteria; and
- the risks that may threaten the achievement of the service organization's service commitments and system requirements, and how controls address those risks.

This report is not intended to be, and should not be, used by anyone other than these specified parties.

SCHILLMAN & COMPANY, LLC

Washington, District of Columbia
July 24, 2024

SECTION 2

MANAGEMENT'S ASSERTION

MANAGEMENT'S ASSERTION

We have prepared the accompanying description of Anaqua's Intellectual Asset Management System, in Section 3, throughout the period July 1, 2023, to June 30, 2024, (the "description") based on the criteria for a description of a service organization's system in DC section 200, *2018 Description Criteria for a Description of a Service Organization's System in a SOC 2® Report* (AICPA, *Description Criteria*), ("description criteria"). The description is intended to provide report users with information about the Intellectual Asset Management System that may be useful when assessing the risks arising from interactions with Anaqua's system, particularly information about system controls that Anaqua has designed, implemented, and operated to provide reasonable assurance that its service commitments and system requirements were achieved based on the trust services criteria relevant to security ("applicable trust services criteria") set forth in TSP section 100, *Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy* (AICPA, *Trust Services Criteria*).

Anaqua uses various subservice organizations for cloud hosting services. The description indicates that complementary subservice organization controls that are suitably designed and operating effectively are necessary, along with controls at Anaqua, to achieve Anaqua's service commitments and system requirements based on the applicable trust services criteria. The description presents Anaqua's controls, the applicable trust services criteria, and the types of complementary subservice organization controls assumed in the design of Anaqua's controls. The description does not disclose the actual controls at the subservice organizations.

We confirm, to the best of our knowledge and belief, that:

- the description presents Anaqua's Intellectual Asset Management System that was designed and implemented throughout the period July 1, 2023, to June 30, 2024, in accordance with the description criteria;
- the controls stated in the description were suitably designed throughout the period July 1, 2023, to June 30, 2024, to provide reasonable assurance that Anaqua's service commitments and system requirements would be achieved based on the applicable trust services criteria, if its controls operated effectively throughout that period, and if the subservice organizations applied the complementary controls assumed in the design of Anaqua's controls throughout that period; and
- the controls stated in the description operated effectively throughout the period July 1, 2023, to June 30, 2024, to provide reasonable assurance that Anaqua's service commitments and system requirements were achieved based on the applicable trust services criteria if complementary subservice organization controls assumed in the design of Anaqua's controls operated effectively throughout that period.

SECTION 3

DESCRIPTION OF THE SYSTEM

OVERVIEW OF OPERATIONS

Company Background

Anaqua, Inc. (the “Company”) provides software and services through a web-based unified platform for intellectual property (IP) – a comprehensive software platform capable of managing and automating the full IP lifecycle of patents, trademarks, designs, trade secrets and contracts. Today, Anaqua’s AQX software is used by nearly a million IP executives, attorneys, paralegals and administrators in corporations and law firms all over the world.

Anaqua has more than doubled in size over the past five years through organic growth, merging with Lecorpio, a leading IP management software solutions company, and acquiring ideaPoint, an innovation management solution provider and AcclaimIP, the patent analytics software solution.

In June 2020, Anaqua acquired IP management software and practice automation provider O P Solutions. The acquisition accelerated Anaqua’s law firm growth strategy and supported the company’s commitment to delivering IP solutions that address the diversified and evolving needs of today’s IP management market. O P Solutions’ flagship product PATTSY WAVE® joined AQX Law Firms as a second distinct brand to help address the varying needs and requirements of the IP law firm market.

Anaqua was founded in 2004 and is headquartered in Boston, Massachusetts, with additional locations in the U.S. as well as Europe and Asia.

Description of Services Provided

Anaqua’s cloud/software as a service (SaaS) solution provides intellectual property and technology scouting solutions to their customers. These software solutions are provided in a SaaS module with the following key components:

- Installation of software
- Configuration
- Upgrading of software
- Performing backups

Anaqua’s Intellectual Asset Management System consists of several integrated products that are bundled into integrated software packages:

- AQX Corporate
- AQX Law Firm
- Lecorpio
- PATTSY WAVE
- ideaPoint Innovation Management

AQX Corporate

The core of Anaqua’s Intellectual Asset Management System, AQX Corporate is made up of the Anaqua Core and Lecorpio solutions. AQX is a software platform that enables corporations to align their IP portfolio strategy with their business objectives and provides law firms powerful new automation and business development tools. With AQX, users can leverage unique analytics and collaboration capabilities to develop IP assets that directly support their business objectives. The AQX solution delivers end-to-end IP management and powerful analytics to maintain the portfolio, artificial intelligence that assesses internal and external data and tools to measure and manage financial performance. AQX delivers actionable intelligence, empowering better business results, driving innovation, enabling freedom to operate (FTO) and brand-protection and delivering competitive advantage in market intelligence.

AQX Law Firm

Anaqua provides a configurable workflow engine and country rules designed to address the unique requirements of IP Law Firms. Anaqua includes a foundational set of features, such as automated system task assignments, notifications and alerts, and integrated e-mail and document management including the option to integrate with third-party solutions.

PATTSY WAVE®

PATTSY WAVE is an IP management software used by hundreds of organizations around the globe to help improve the efficiency and accuracy of their domestic and international IP practices. PATTSY WAVE delivers docketing, plus integrated workflow, and collaboration tools. Some of the key features in PATTSY WAVE include AutoDocket, integration with PTO offices worldwide, IDS management, e-mail integration, and client letter templates and forms. Our signature “single-screen design” and focus on practice automation is a distinguishing feature of PATTSY WAVE. The browser-based interface supports anywhere/anytime access. PATTSY WAVE supports IP teams in managing patents and trademarks and integrates with ANAQUA’s Services for managing annuities.

Lecorpio

Lecorpio software provides a secure, web-based portal for centrally managing the entire IP lifecycle - from the submission of disclosures and trademark search requests all the way through to the payment of annuities and renewals, and ongoing opposition filings, enforcement actions, arbitration, litigation, contracts, license agreements and more. And with robust reporting and analytics, IP departments are able to make data-driven decisions about what, where and when to file with a thorough understanding of the financial implications of those decisions, the potential risks, and opportunities for maximizing value.

ideaPoint

ideaPoint is a software solution that offers management compliance and successful investigator-initiated studies programs. It assists pharmaceutical and medical device companies with managing global intellectual asset management (IAS) programs, complying with evolving regulatory guidelines, documenting necessary reviews and approvals, tracking payments and product shipping, recording patient enrollment and other key milestones, and reporting on anything across the portfolio.

PRINCIPAL SERVICE COMMITMENTS AND SYSTEM REQUIREMENTS

Anaqua designs its processes and procedures related to the Intellectual Asset Management System to meet its objectives for its Intellectual Asset Management System services. Those objectives are based on the service commitments that Anaqua makes to user entities, the laws and regulations that govern the provision of the Intellectual Asset Management System services, and the financial, operational, and compliance requirements that Anaqua has established for the services. The Intellectual Asset Management System services of Anaqua are subject to the relevant regulatory and industry information and data security requirements in which Anaqua operates.

Security commitments to user entities are documented and communicated in Service Level Agreements (SLAs) and other customer agreements, such as contracts, as well as in the description of the service offering provided online. The principal security commitments are standardized and include, but are not limited to, the following:

- use commercial industry standard secure encryption methods to protect customer data at rest and in transit;
- maintain secure software development processes to ensure consistent quality that goes across policy, people, processes, and technology;
- maintain role-based security to protect the security of information provided to Anaqua;
- maintain anti-virus protection, perform vulnerability scanning, and conduct periodic penetration testing to detect and prevent security vulnerabilities from being introduced into production systems;
- utilize strong passwords and multi-factor authentication for access to systems; and
- monitoring of logs to identify suspicious activity or unauthorized access.

Anaqua establishes operational requirements that support the achievement of the principal service commitments, relevant laws and regulations, and other system requirements.

Such requirements are captured in Anaqua’s system policies and procedures, system design documentation, and contracts with customers. Information security policies define an organization-wide approach to how systems and data are protected. These include policies around how the service is designed and developed, how the system is operated, how the internal business systems and networks are managed and how employees are hired, trained, and managed. In addition to these policies, standard operating procedures have been documented on how to carry out specific manual and automated processes required in the operation and development of the Intellectual Asset Management System.

In accordance with our assertion, and the description criteria, the aforementioned service commitments and requirements are those principal service commitments and requirements common to the broad base of users of the system and may therefore not fully address the specific service commitments and requirements made to all system users, in each individual case.

COMPONENTS OF THE SYSTEM USED TO PROVIDE THE SERVICE

System Boundaries

A system is designed, implemented, and operated to achieve specific business objectives in accordance with management-specified requirements. The purpose of the system description is to delineate the boundaries of the system, which includes the services outlined above and the five components described below: infrastructure, software, people, procedures, and data.

Infrastructure and Software

The Intellectual Asset Management System is hosted within the IBM and Microsoft Azure infrastructure. Anaqua does not own or maintain hardware located in the IBM and Microsoft Azure data centers. Anaqua operates under a shared security responsibility model, where IBM and Microsoft Azure are responsible for the security of the underlying cloud infrastructure (i.e., physical infrastructure, geographical regions, availability zones, edge locations, operating, managing and controlling the components from the host operating system, virtualization layer and storage) and Anaqua is responsible for securing the application platform deployed in the IBM and Microsoft Azure Cloud Management Consoles (i.e., applications, identity access management, operating system and network firewall configurations, server-side encryption). Production servers and client facing applications are logically and physically secured from Anaqua’s internal corporate information systems.

The production network is administered remotely; access to the production network requires an established Virtual Private Network (VPN) and remote desktop protocol (RDP) connection authenticated via two-factor authentication (2FA). Access to the public facing applications within the Intellectual Asset Management System is encrypted via TLS to help ensure a secure transmission over the Internet for the platform. In addition, firewalls are utilized to restrict access to the production platform.

The in-scope infrastructure consists of the following systems as shown in the table below:

Primary Infrastructure		
System	Business Function Description	Platform
Firewalls	IBM and Microsoft Azure firewalls protects the production network perimeter and limits inbound and outbound production network access to IBM and Microsoft Azure resources within the cloud environment.	IBM & Microsoft Azure
VPN	Utilized to enable a secure connection to the Intellectual Asset Management System production environment for authorized personnel.	OpenVPN

Primary Infrastructure		
System	Business Function Description	Platform
Network Domain	Active Directory (AD) is utilized to manage user accounts and authentication requirements for accessing the production network.	Microsoft Windows Server
Service Request Ticket Management	Enterprise-wide system used for service desk, workflow, and access management requests handled by the information teams and human resources personnel.	Zendesk
Cloud Platform Management Consoles	Provides administration of controlling user access and permissions to manage the production infrastructure of the Intellectual Asset Management System.	IBM & Microsoft Azure
Intellectual Asset Management System Applications	Provides intellectual property and technology scouting solutions to customers consisting of several integrated products that are bundled into integrated software packages: • AQX Corporate • AQX Law Firm • PATTSY WAVE • Lecorpio • ideaPoint Innovation Management	
Server	Client web servers utilized to support aspects of the Intellectual Asset Management System and services.	Microsoft Windows Server, Azure Virtual Server, and IBM Virtual Server
Database	Utilized to manage and store data for the Intellectual Asset Management System and systems, including the AQX Corporate, AQX Law Firm, PATTSY WAVE, Lecorpio, and ideaPoint Innovation Management applications.	Microsoft SQL Server, Azure Virtual Server, and IBM Bare Metal Server

People

The following groups are involved in the operation and maintenance of the Anaqua Intellectual Asset Management System:

- Executive Management – responsible for overseeing company-wide activities, establishing, and accomplishing goals, and overseeing objectives.
- Human Resources (HR) – responsible for HR policies, practices, and processes with a focus on key HR department delivery areas (e.g., talent acquisitions, employee retention, compensation, employee benefits, performance management, employee relations and training, and development).
- Engineering – responsible for developing applications and services that compose the Intellectual Asset Management System.
- Hosting Team – responsible for managing the customer production hosted environment.
- IT Team - responsible for provisioning internal environments.

Procedures

Access, Authentication, and Authorization

Documented security policies and procedures are in place regarding system settings, authentication, access control, security monitoring, and password protection.

Access to system information, including confidential customer information, is protected by multiple authentication layers. In order to connect to the Intellectual Asset Management System production systems, Anaqua personnel are required to first connect to the encrypted VPN system, via a username and password integrated with AD when accessing the IBM or Microsoft Azure production environments. Access to the VPN must be administered by IBM as part of a managed hosting agreement purchased by Anaqua with approval from the chief information officer (CIO) or the chief executive officer (CEO). Access and authentication to the VPN for the Azure production environment is controlled by Anaqua. Once connected to the VPN, Anaqua personnel can authenticate to the IBM and Azure production domains, application servers, and databases through RDP connection via a username and password along with 2FA. Authentication configurations to the IBM Cloud Management Console is managed by IBM. Anaqua personnel authenticate to the IBM and Microsoft Azure Cloud Management Consoles via a username and password, along with 2FA, as set by Anaqua. The in-scope systems are configured to authenticate users with a unique user account and enforce minimum password requirements.

Access to the front-end applications requires a unique user account using an e-mail address and enforce minimum password requirements. The front-end applications are configured with baseline password settings that can then be customized by customers for their instance. Furthermore, privileged access to in-scope systems is restricted to authorized personnel.

Access Requests and Access Revocation

A process has been established by Anaqua to manage user access requests, modifications, and deletions. The process varies based on the type of access needed. The corporate IT team is responsible for assigning and maintaining access rights to the corporate systems based on the individual's role and business justification. User provisioning is requested in the HR onboarding form and attached to a Zendesk ticket. The IT department will provision access in AD as per the requested permissions of the onboarding form attached to the associated Zendesk ticket. Anaqua personnel are set up with an AD account allowing them to access the systems and resources. Users requiring access to the IBM and Azure production networks are requested in the Zendesk ticketing system and require approval from the CIO or the CEO. Access requests to the IBM production environment are then routed to IBM for provisioning as part of the managed hosting agreement with IBM. Access requests to the Azure production environment are controlled by Anaqua and Zendesk tickets are routed to management for approvals. In the event of a termination, HR personnel will notify corporate IT for access revocation via a termination ticket. In addition, to help ensure access privileges in the production network are commensurate with job responsibilities, the senior director of hosting operations will perform a formal review of system access rights on a quarterly basis. If any individual is deemed to have inappropriate access, a separate request is raised with IBM to revoke access. A ticket would be raised and handled internally by Anaqua personnel if any individual is deemed to have inappropriate access to the production environment.

Access reviews are conducted annually as part of Anaqua's annual risk assessment process. Customers are responsible for provisioning access to their instance of the Intellectual Asset Management System products, as well as configure their own password rules.

Network and Data Security

A firewall is in place to filter unauthorized inbound network traffic from the internet. Information involved in application services passing over public networks is protected from fraudulent activity, contract dispute and unauthorized disclosure and modification through the use of firewalls and encryption methods. Encryption technologies or secured communication channels are used to protect transmission of data and other communications beyond connectivity access points. An encrypted VPN is required for remote access to the production environment to help ensure the security and integrity of the data passing over the public network. A policy is in place to guide personnel on the use and protection of cryptographic keys to protect the confidentiality, authenticity, and/or integrity of information. Groups of information services, users and information systems are segregated on networks. Furthermore, an inventory of system assets and components is maintained to classify and manage the information assets.

To further protect the network, antivirus software is installed on production systems to detect and prevent the transmission of data or files that contain certain virus signatures recognized by the antivirus software. In addition, a management-defined change control process is used for the implementation of software.

Change Management

Documented policies and procedures are in place to guide personnel in the change management process which includes documentation, testing, and approval by the quality assurance (QA) team. The change management procedures are updated regularly and made accessible to employees in a shared location. Infrastructure changes are documented in a ticketing system and require approval from IT management. Product changes are documented and tracked in a ticketing system and performed by the engineering team. Once developed, the change is tested by the QA team and if approved, the change is merged into the main branch; approved builds are then bundled into a release bundle. Once the engineering team has finalized the release, whether it be major or minor release, or service packs, the executable, along with release notes, are placed in a shared folder by the engineering team on the corporate network accessible by Anaqua personnel. Access to modify source code contained in the version control software is restricted to those with a business need. Release notes are made available to customers to decide whether to request implementation of the latest release to their environment.

If a customer elects to enroll in the release, the customer raises a request with the Anaqua support team who then creates an internal ticket with the hosting team to implement the release to that customer's environment. To implement the release on the customer's environment, the hosting team must be authenticated to the production network via RDP and copy the executable from the shared folder on the corporate network to the production network and servers. Separate development, test/QA, and production environments are maintained. In addition to implementing upgrades, Anaqua's hosting team also run backup requests and scripts requested from the support organization. While customers can be on different releases of the software, there are no separate versions of the software for a given customer; every customer on a specific release are using the same codebase. Furthermore, a code review scan is in place to detect critical vulnerabilities for each application release.

Incident Response

Incident response and escalation policies and procedures are in place to manage unexpected incidents impacting the business. The procedures are reviewed on a periodic basis to help ensure they are still effective in meeting the business objectives and include establishing roles and responsibilities for the design, implementation, maintenance, and execution of the incident response program. Incident events can be reported by internal personnel, customers, or vendors via an IT request e-mail. Event coordinators are defined across the various Anaqua regions to help ensure that an event response team is assembled to properly assess the event and determine the proper course of action. Events are then triaged for false positives and a help desk ticket that captures the incident, incident source, initial severity and priority is created for events that are considered incidents. Management utilizes a ticketing system for documenting, communicating, and collaborating to resolve any identified incidents with customers. Furthermore, the entity monitors infrastructure and software for noncompliance with the standards, which could threaten the achievement of Anaqua's objectives. Anaqua has also implemented a disaster recovery / business continuity plan to help ensure the required level of continuity for information security during an adverse situation. Corrective measures or changes that occur as a result of incidents and identified deficiencies follow the standard change control process.

System Monitoring

Several monitoring systems, including event logging, are in place to monitor the production environment. A performance monitoring tool is utilized to identify and evaluate ongoing system security threats, changing resource utilization needs and unusual system activity and event logs that record user activities, exceptions, faults, and information security events are regularly reviewed. The entity conducts vulnerability scans designed to identify potential vulnerabilities or misconfigurations on a weekly basis and engages third-party vendors to perform internal penetration and external penetration testing on an annual basis. Vulnerabilities detected are triaged and monitored through resolution. Information security events are reported to the help desk and tracked through resolution. Furthermore, production systems are registered and monitored for antivirus compliance to detect and prevent the transmission of data or files that contain certain virus signatures recognized by the antivirus software.

Data

The following table describes the information used and supported by the system.

Data Used and Supported by the System		
Data Description	Data Reporting	Classification
Client business data such as intellectual property business data and invention disclosures.	Client business data that may be accessed or maintained are not used in reporting.	Confidential or Personal

Significant Changes During the Period

There were no significant changes that are likely to affect report users' understanding of how the in-scope system is used to provide the services covered by this examination during the period.

Subservice Organizations

The cloud hosting services provided by IBM and Microsoft Azure were not included within the scope of this examination.

The following table presents the applicable Trust Services criteria that are intended to be met by controls at IBM and Microsoft, alone or in combination with controls at Anaqua, and the types of controls expected to be implemented at IBM and Microsoft Azure to achieve Anaqua's principal service commitments and system requirements based on the applicable trust services criteria.

Control Activity Expected to be Implemented by IBM and Microsoft Azure	Applicable Trust Services Criteria
IBM and Microsoft Azure are responsible for managing logical access to the underlying network, virtualization management, and storage devices for their cloud hosting services where the IBM and Microsoft Azure hosted production applications reside.	CC6.1, CC6.2, CC6.5, CC6.6, CC6.7
IBM and Microsoft Azure are responsible for restricting physical access to data center facilities, backup media, and other system components including firewalls, routers, and servers for IBM and Microsoft Azure hosted applications.	CC6.4, CC6.5, CC7.2
IBM and Microsoft Azure are responsible for restricting physical access to data center facilities, backup media, and other system components including firewalls, routers, and servers for IBM and Microsoft Azure hosted applications.	CC7.1, CC7.2

CONTROL ENVIRONMENT

The control environment at Anaqua is the foundation for the other areas of internal control. It sets the tone of the organization and influences the control consciousness of its personnel. The components of the control environment factors include the integrity and ethical values, management's commitment to competence; its organizational structure; the assignment of authority and responsibility; and the oversight and direction provided by the board of directors and operations management.

Integrity and Ethical Values

The effectiveness of controls cannot rise above the integrity and ethical values of the people who create, administer, and monitor them. Integrity and ethical values are essential elements of the control environment, affecting the design, administration, and monitoring of other components. Anaqua has established an employee handbook and code of conduct which documents the organizational policy statements that communicate workforce conduct standards and enforcement procedures. The policies are reviewed annually and made available to employees via the company's HR portal. Management requires employees to acknowledge the employee handbook as a component of the onboarding process and on an annual basis. All employees are required to participate in Code of Conduct training, and compliance is formally tracked.

Board of Directors Oversight

Anaqua's control consciousness is influenced significantly by the board of directors. The board of directors establishes and maintains a formal set of bylaws which describes their responsibilities and oversight of management's system of internal control. The board of directors has members who are, by majority, independent from management and are objective in evaluations and decision making. On an annual basis, management personnel provide the results of external controls assessment reports to the board of directors.

Organizational Structure and Assignment of Authority and Responsibility

Anaqua's organizational structure provides the framework within which its activities for achieving entity-wide objectives are planned, executed, controlled, and monitored. Establishing a relevant organizational structure includes considering key areas of authority and responsibility and lines of reporting. Anaqua has developed an organizational structure suited to its needs. Anaqua's organizational structure depends, in part, on its size and the nature of its activities.

This factor includes how authority and responsibility for operating activities are assigned and how reporting relationships and authorization hierarchies are established. It also includes policies relating to business practices, knowledge and experience of key personnel, and resources provided for carrying out duties. Policies and communications are in place to help ensure that personnel understand Anaqua's objectives, know how their individual actions interrelate and contribute to those objectives, and recognize how and for what they will be held accountable. A documented organizational chart is in place that defines organizational structures, lines of reporting, and areas of authority. Position descriptions are documented and include the expected behavior and skills needed to facilitate the accomplishment of objectives related to the employee's area of responsibility.

Commitment to Competence

Competence is the knowledge and skills necessary to accomplish tasks that define employees' roles and responsibilities. Anaqua's commitment to competence includes management's consideration of the competence levels for particular jobs and how those levels translate into requisite skills and knowledge. Anaqua's commitment to competence begins with a background check that is performed, as permitted by local laws, as part of the onboarding procedures. Furthermore, Anaqua has policies and procedures in place that outline the performance evaluation process as well as the competency and training requirements for personnel. Executive management has created a training program for its employees, including a data security training for employees upon hire and an annual security awareness training thereafter. Additionally, contractors are required to review and sign the data security policy upon hire and are required to attend the annual security awareness training on an annual basis thereafter, to understand their obligations and responsibilities to comply with the entity's security policies. Management conducts performance review of employees on an annual basis to evaluate performance of employees against expected levels of performance and conduct.

Accountability

Management establishes accountability by setting a strong tone at the top and holding those accountable for internal control responsibilities. Management communicates the internal control responsibilities and the criteria that

employees will be measured against as well as incentives and other rewards. Management formally documents an organizational strategy and updates it on an annual basis to align internal control responsibilities and performance measures with company business objectives.

RISK ASSESSMENT

Objective Setting

Management formally documents an organization strategy and objectives that are used to determine entity structure and performance metrics. The objectives documented by executive management are specific, measurable, attainable, relevant, and time-bound (SMART). Further, executive management reviews policies, procedures, and other control documents for alignment to Anaqua's objectives on an annual basis. Information security compliance audits are performed at least annually to demonstrate compliance with relevant laws, regulations, and standards.

Risk Identification and Analysis

Documented policies and procedures are in place to guide personnel when performing a risk assessment. Management has defined a formal risk assessment process that specifies the process for identifying internal and external threats and vulnerabilities, evaluating, and addressing risks and defining specified risk tolerances. A formal risk assessment is performed on at least an annual basis to identify internal and external threats and vulnerabilities that could impair system commitments and requirements. Identified risks are rated using a risk evaluation process and ratings are approved by the Information Security Management Committee (ISMC), on an annual basis.

Risk Factors

Management considers risks that can arise from both external and internal factors including the following:

External Factors

- Technological developments
- Changing customer needs or expectations
- Competition that could alter marketing or service activities
- New legislation and regulation that could force changes in policies and strategies
- Natural catastrophes that could lead to changes in operations or information systems
- Economic changes that could have an impact on management decisions

Internal Factors

- Significant changes in policies, processes, or personnel
- Types of fraud
- Fraud incentives and pressures for employees
- Fraud opportunities
- Employee attitudes and rationalizations for fraud
- A disruption in information systems processing
- The quality of personnel hired, and methods of training utilized
- Changes in management responsibilities

Potential for Fraud

On an annual basis, management identifies and assesses the types of fraud (e.g., fraudulent reporting, loss of assets, unauthorized system access, overriding controls) that could impact their business and operations. As part of management's assessment of fraud risks, management considers key fraud factors such as incentives, pressures, opportunity for unauthorized access or use of data, and employee morale and attitude.

Risk Mitigation

Once risks have been identified and analyzed, the results are reviewed with management for appropriateness and accuracy against the risk acceptance criteria. Management will then decide how to address risks based on the risk assessment score. Risk treatment options include avoid, mitigate, transfer, and accept. Risks are then monitored to determine the effectiveness of the response plans. Risk owners are responsible for developing control activities to support the achievement of objectives as a result of the risk assessment performed.

Risks can also stem from the use of vendors. To mitigate vendor risk, prior to onboarding a vendor, a signed vendor agreement and non-disclosure agreement is required prior to sharing information designated as confidential with third parties. On an annual basis, management will also collect SOC 2 or similar reports from key vendors for review. A supplier management policy is in place to guide personnel in the new supplier acceptance criteria, new suppliers review and acceptance, and existing suppliers review.

Furthermore, the risk management program includes the use of insurance to offset minimize the financial impact of loss events that would otherwise impair the ability of the entity to meet its objectives.

Selection and Development of Control Activities

The applicable trust services criteria and related control activities are included in Section 4 of this report to eliminate the redundancy that would result from listing the items in this section and repeating them in Section 4. Although the applicable trust criteria and related control activities are included in Section 4, they are, nevertheless, an integral part of Anaqua's description of the system.

The description of the service auditor's tests of operating effectiveness and the results of those tests are also presented in Section 4, the Testing Matrices, adjacent to the service organization's description of controls. The description of the tests of operating effectiveness and the results of those tests are the responsibility of the service auditor and should be considered information provided by the service auditor.

TRUST SERVICES CRITERIA AND RELATED CONTROL ACTIVITIES

Integration with Risk Assessment

Along with assessing risks, management has identified and put into effect actions needed to address those risks. In order to address risks, control activities have been placed into operation to help ensure that the actions are carried out properly and efficiently. Control activities serve as mechanisms for managing the achievement of the security categories.

Selection and Development of Control Activities

The applicable trust services criteria and related control activities are included in Section 4 of this report to eliminate the redundancy that would result from listing the items in this section and repeating them in Section 4. Although the applicable trust services criteria and related control activities are included in Section 4, they are, nevertheless, an integral part of Anaqua's description of the system.

The description of the service auditor's tests of operating effectiveness and the results of those tests are also presented in Section 4, the Testing Matrices, adjacent to the service organization's description of controls. The description of the tests of operating effectiveness and the results of those tests are the responsibility of the service auditor and should be considered information provided by the service auditor.

Trust Services Criteria Not Applicable to the In-Scope System

All criteria within the security categories are applicable to the Intellectual Asset Management System.

INFORMATION AND COMMUNICATION SYSTEMS

Pertinent information must be identified, captured, and communicated in a form and timeframe that enable people to carry out their responsibilities. Information systems produce reports containing operational, financial, and compliance-related information that make it possible to run and control the business. They deal not only with internally generated data, but also information about external events, activities, and conditions necessary to inform business decision-making and external reporting. Effective communication also must occur in a broader sense, flowing down, across, and up the organization. Personnel must receive a clear message from top management that control responsibilities must be taken seriously. They must understand their own role in the internal control system, as well as how individual activities relate to the work of others. They must have a means of communicating significant information upstream. There also needs to be effective communication with external parties, such as customers, suppliers, regulators, and shareholders.

Anaqua obtains, generates, and uses relevant quality information to support the functioning of internal control. Anaqua has a Data Security Policy that identifies information required to support the functioning of internal control and achievement of objectives and associated protection, access rights, and retention requirements. This policy is formally documented and reviewed on an annual basis. Inventories of in-scope system assets and components are also maintained to classify and manage the information assets. Additionally, IT personnel monitors relevant key systems to identify potential anomalous activity related to security (e.g., malicious activity, login/user anomalies). Data flow diagrams, process flowcharts, narratives and procedures manuals are documented and maintained by management to identify the relevant internal and external information sources of the in-scope systems. Event logs are also kept to record user activities, exceptions, faults, and information security events and regularly reviewed.

Internal Communications

Anaqua has implemented various methods of communication to help provide assurance that employees understand their individual roles and responsibilities and that significant events are communicated. These methods include orientation for new employees, training for employees, and the use of e-mail messages to communicate time-sensitive information. Employees are encouraged to communicate to their lead/mentor, supervisor/manager, or senior/executive management.

Internal communications begin during the onboarding process. Upon onboarding, employees sign and acknowledge the code of conduct and employee handbook; the employee handbook must be re-acknowledged on an annual basis thereafter. Furthermore, Anaqua's policies and procedures, code of conduct and employee handbook are made available to employees through the entity's shared network drives and e-mail communications.

External Communications

Anaqua has also implemented various methods of communication to help provide assurance that customers understand the roles and responsibilities in processing their transactions and communication of significant events. These methods include customer support transitions procedures shared with customers upon onboarding. Changes to commitments, requirements, and responsibilities are communicated to third parties, external users, and customers via updated agreements, website notices, or mass notifications. Documented escalation procedures for reporting failure incidents, concerns, and other complaints are in place and shared with external parties. Signed nondisclosure agreements are required prior to sharing information designated as confidential with third parties.

Anaqua's security commitments and the associated system requirements are documented in customer subscription agreements. Release notes are communicated to customers by the product team.

MONITORING

Monitoring is a process that assesses the quality of internal control performance over time. It involves assessing the design and operation of controls and taking necessary corrective actions. This process is accomplished through ongoing activities, separate evaluation, or a combination of the two. Monitoring activities also include using information from communications from external parties such as user entity complaints and regulatory comments that may indicate problems or highlight areas in need of improvement. Management has implemented a self-survey assessment and compliance program to help ensure the controls are consistently applied as designed. Additionally, management reviews policies, procedures and other control documents for accuracy and applicability on an annual basis.

Ongoing Monitoring

Ongoing monitoring procedures and controls are in place for technical, administrative, and physical safeguards that support the control environment. Monitoring software is used to identify and evaluate ongoing system security threats, changing resource utilization needs and unusual system activity. A formal risk assessment is performed on at least an annual basis to identify internal and external threats and vulnerabilities that could impair system commitments and requirements. Furthermore, management engages third parties to perform independent assessments of the controls environment annually to assess the effectiveness of controls within the environment.

Separate Evaluations

Evaluation of an entire internal control system may be prompted by a number of reasons: major strategy or management change, major acquisitions or dispositions, or significant changes in operations or methods of processing financial information. Evaluations of internal controls vary in scope and frequency, depending on the significance of risks being controlled and importance of the controls in reducing the risks. Controls addressing higher priority risks and those most essential to reducing a given risk will tend to be evaluated more often.

Often evaluations take the form of self-surveys, where persons responsible for a particular unit or function will determine the effectiveness of controls for their activities and relay them to management of the company. These assessments are considered by IT management, along with any other internal control evaluations. Senior management is made aware of high-risk vulnerabilities, deviations, and controls gaps identified as part of these evaluations. The findings of these efforts are utilized to help ensure follow-up actions are taken and subsequent evaluations are modified, as necessary.

Subservice Organization Monitoring

Management reviews the third-party attestation reports of subservice organizations on an annual basis to help ensure the design and operating effectiveness of controls at the subservice organizations are meeting agreed upon expectations. Additionally, Anaqua is monitoring and assessing the subservice organizations' services as a part of its daily business operations.

Evaluating and Communicating Deficiencies

Deficiencies in management's internal control system surface from many sources, including the company's ongoing monitoring procedures, separate evaluations of the internal control system and external parties. Management has developed protocols to help ensure findings of internal control deficiencies are reported. Deficiencies discovered as part of internal evaluations or third-party validation are communicated to management who is responsible for developing remediation plans that are recorded and tracked. Management evaluates the specific facts and circumstances related to deficiencies in internal control procedures and make the decision for addressing deficiencies based on whether the incident was isolated or requires a change in the company's procedures or personnel.

System Incident Disclosures

No system incidents occurred that were the result of controls that were not suitably designed or otherwise resulted in a significant failure of the achievement of one or more of the service commitments and systems requirements.

COMPLEMENTARY CONTROLS AT USER ENTITIES

Anaqua's controls are designed to provide reasonable assurance that the principal service commitments and system requirements can be achieved without the implementation of complementary controls at user entities. As a result, complementary user entity controls are not required, or significant, to achieve the principal service commitments and system requirements based on the applicable trust services criteria.

SECTION 4

TESTING MATRICES

TESTS OF OPERATING EFFECTIVENESS AND RESULTS OF TESTS

Scope of Testing

This report on the controls relates to the Intellectual Asset Management System provided by Anaqua. The scope of the testing was restricted to the Intellectual Asset Management System and its boundaries as defined in Section 3. Schellman conducted the examination testing over the period July 1, 2023, through June 30, 2024.

Tests of Operating Effectiveness

The tests applied to test the operating effectiveness of controls are listed alongside each of the respective control activities within the Testing Matrices. Such tests were considered necessary to evaluate whether the controls were sufficient to provide reasonable, but not absolute, assurance that the applicable trust services criteria were achieved during the examination period. In selecting the tests of controls, Schellman considered various factors including, but not limited to, the following:

- the nature of the control and the frequency with which it operates;
- the control risk mitigated by the control;
- the effectiveness of entity-level controls, especially controls that monitor other controls;
- the degree to which the control relies on the effectiveness of other controls; and
- whether the control is manually performed or automated.

The types of tests performed with respect to the operational effectiveness of the control activities detailed in this section are briefly described below:

Test Approach	Description
Inquiry	Inquired of relevant personnel with the requisite knowledge and experience regarding the performance and application of the related control activity. This included in-person interviews, telephone calls, e-mails, web-based conferences, or a combination of the preceding.
Observation	Observed the relevant processes or procedures during fieldwork. This included, but was not limited to, witnessing the performance of controls or evidence of control performance with relevant personnel, systems, or locations relevant to the performance of control policies and procedures.
Inspection	Inspected the relevant audit records. This included, but was not limited to, documents, system configurations and settings, or the existence of sampling attributes, such as signatures, approvals, or logged events. In some cases, inspection testing involved tracing events forward to consequent system documentation or processes (e.g., resolution, detailed documentation, alarms, etc.) or vouching backwards for prerequisite events (e.g., approvals, authorizations, etc.).

Sampling

Consistent with American Institute of Certified Public Accountants (AICPA) authoritative literature, Schellman utilizes professional judgment to consider the tolerable deviation rate, the expected deviation rate, the audit risk, the characteristics of the population, and other factors, in order to determine the number of items to be selected in a sample for a particular test. Schellman, in accordance with AICPA authoritative literature, selected samples in such a way that the samples were expected to be representative of the population. This included judgmental selection methods, where applicable, to ensure representative samples were obtained.

System-generated population listings were obtained whenever possible to ensure completeness prior to selecting samples. In some instances, full populations were tested in cases including but not limited to, the uniqueness of the event or low overall population size.

Reliability of Information Provided by the Service Organization

Observation and inspection procedures were performed related to certain system-generated reports, listings, and queries to assess the accuracy and completeness (reliability) of the information used in the performance of our testing of the controls.

Test Results

The results of each test applied are listed alongside each respective test applied within the Testing Matrices. Test results not deemed as control deviations are noted by the phrase “No exceptions noted.” in the test result column of the Testing Matrices. Any phrase other than the aforementioned, constitutes either a test result that is the result of non-occurrence, a change in the application of the control activity, or a deficiency in the operating effectiveness of the control activity. Testing deviations identified within the Testing Matrices are not necessarily weaknesses in the total system of controls, as this determination can only be made after consideration of controls in place at user entities and subservice organizations, if applicable, and other factors.

SECURITY CATEGORY

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
Control Environment			
CC1.1 – COSO Principle 1: The entity demonstrates a commitment to integrity and ethical values.			
CC1.1.1	An employee handbook and code of conduct are documented to communicate workforce conduct standards and enforcement procedures.	Inspected the employee handbook and code of conduct to determine that an employee handbook and code of conduct were documented and communicated workforce conduct standards and enforcement procedures.	No exceptions noted.
CC1.1.2	New hires are required to acknowledge the employee handbook as a component of the onboarding process.	Inspected the employee handbook acknowledgment for a sample of employees hired during the period to determine that the employee handbook was acknowledged as a component of the onboarding process for each employee sampled.	No exceptions noted.
CC1.1.3	Background checks are performed for new hires as a component of the onboarding process.	Inspected the employee background check for a sample of employees hired during the period to determine that background checks were performed for new hires as a component of the onboarding process for each employee sampled.	No exceptions noted.

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC1.1.4	Personnel are required to acknowledge the employee handbook on an annual basis.	Inspected the employee handbook acknowledgment for a sample of current employees to determine that personnel were required to acknowledge the employee handbook during the period for each employee sampled.	No exceptions noted.
CC1.1.5	Management formally documents a code of business conduct and ethics that outlines the organization's ethical values.	Inspected the code of business conduct and ethics to determine that management formally documented a code of business conduct and ethics that outlined the organization's ethical values.	No exceptions noted.
CC1.2 – COSO Principle 2: The board of directors demonstrates independence from management and exercises oversight of the development and performance of internal control.			
CC1.2.1	The board of directors establishes and maintains a formal set of by-laws which describes their responsibilities and oversight of management's system of internal control.	Inspected the board of directors' by-laws to determine that the board of directors established and maintained a formal set of by-laws that described their responsibilities and oversight of management's system of internal control.	No exceptions noted.
CC1.2.2	The board of directors has members who are, by majority, independent from management and are objective in evaluations and decision making.	Inquired of the senior director of hosting operations regarding the board of directors to determine that the board of directors had members who were, by majority, independent from management and were objective in evaluations and decision making.	No exceptions noted.
		Inspected the members of the board of directors to determine that the board of directors had members who were, by majority, independent from management.	No exceptions noted.
CC1.2.3	Management personnel provide the results of external controls assessment reports to the board of directors on an annual basis.	Inspected the most recent board of directors meeting agenda to determine that management personnel provided the results of external control assessment reports to the board of directors during the period.	No exceptions noted.
CC1.3 – COSO Principle 3: Management establishes, with board oversight, structures, reporting lines, and appropriate authorities and responsibilities in the pursuit of objectives.			
CC1.3.1	A documented organizational chart is in place that defines organizational structures, lines of reporting, and areas of authority.	Inspected the organizational chart to determine that a documented organizational chart was in place that defined organizational structures, lines of reporting, and areas of authority.	No exceptions noted.

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC1.3.2	Position descriptions are documented and include the expected behavior and skills needed to facilitate the accomplishment of objectives related to the employee's area of responsibility.	Inspected the job position description for a sample of employment positions to determine that position descriptions were documented and included the expected behavior and skills needed to facilitate the accomplishment of objectives related to the employee's area of responsibility for each employment position sampled.	No exceptions noted.
CC1.4 – COSO Principle 4: The entity demonstrates a commitment to attract, develop, and retain competent individuals in alignment with objectives.			
CC1.4.1	Policies and procedures are in place that outline the performance evaluation process as well as the competency and training requirements for personnel.	Inspected the employee handbook and competence policy to determine that policies and procedures were in place that outlined the performance evaluation process as well as the competency and training requirements for personnel.	No exceptions noted.
CC1.4.2	Position descriptions are documented and include the expected behavior and skills needed to facilitate the accomplishment of objectives related to the employee's area of responsibility.	Inspected the job position description for a sample of employment positions to determine that position descriptions were documented and included the expected behavior and skills needed to facilitate the accomplishment of objectives related to the employee's area of responsibility for each employment position sampled.	No exceptions noted.
CC1.4.3	Executive management has created a training program for its employees and included professional development courses, skills-based courses, as well as Anaqua product-related trainings.	Inquired of the senior director of hosting operations regarding the training program to determine that executive management created a training program for its employees and included professional development courses, skills-based courses, as well as Anaqua product-related trainings.	No exceptions noted.
		Inspected the learning platform to determine that a training program was in place for employees and included professional development courses, skills-based courses, as well as Anaqua product-related trainings.	No exceptions noted.

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC1.4.4	Employees are provided security awareness training upon hire, and on an annual basis thereafter, to understand their obligations and responsibilities to comply with the entity's security policies.	Inquired of the senior director of hosting operations regarding security awareness training to determine that employees were provided security awareness training upon hire, and on an annual basis thereafter, to understand their obligations and responsibilities to comply with the entity's security policies.	No exceptions noted.
		Inspected the security awareness training program and documentation of completion for a sample of employees hired during the period to determine that security awareness training was provided to new employees upon hire to understand their obligations and responsibilities to comply with the entity's security policies for each employee sampled.	No exceptions noted.
		Inspected the security awareness training program and documentation of completion for a sample of current employees to determine that security awareness training was provided to employees during the period to understand their obligations and responsibilities to comply with the entity's security policies during the period for each employee sampled.	No exceptions noted.
CC1.4.5	Contractors are required to review and sign the data security policy upon hire and are required to attend the annual security awareness training on an annual basis thereafter, to understand their obligations and responsibilities to comply with the entity's security policies.	Inquired of the senior director of hosting operations regarding security awareness training to determine that contractors are required to review and sign the data security policy upon hire and are required to attend the annual security awareness training on an annual basis thereafter, to understand their obligations and responsibilities to comply with the entity's security policies.	No exceptions noted.
		Inspected the data security policy acknowledgment for a sample of contractors hired during the period to determine that contractors are required to review and sign the data security policy upon hire and are required to attend the annual security awareness training on an annual basis thereafter, to understand their obligations and responsibilities to comply with the entity's security policies.	No exceptions noted.

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Inspected the data security policy acknowledgement for a sample of current contractors to determine that contractors are required to review and sign the data security policy upon hire and are required to attend the annual security awareness training on an annual basis thereafter, to understand their obligations and responsibilities to comply with the entity's security policies.	No exceptions noted.
CC1.4.6	Background checks are performed for new hires as a component of the onboarding process.	Inspected the employee background check for a sample of employees hired during the period to determine that background checks were performed for new hires as a component of the onboarding process for each employee sampled.	No exceptions noted.
CC1.4.7	Management conducts a performance review of employees on an annual basis to evaluate performance of employees against expected levels of performance and conduct.	Inspected the most recent performance review documentation for a sample of current employees to determine that management conducted a performance review of employees during the period to evaluate performance of employees against expected levels of performance and conduct for each employee sampled.	No exceptions noted.
CC1.5 – COSO Principle 5: The entity holds individuals accountable for their internal control responsibilities in the pursuit of objectives.			
CC1.5.1	A documented organizational chart is in place that defines organizational structures, lines of reporting, and areas of authority.	Inspected the organizational chart to determine that a documented organizational chart was in place that defined organizational structures, lines of reporting, and areas of authority.	No exceptions noted.
CC1.5.2	Position descriptions are documented and include the expected behavior and skills needed to facilitate the accomplishment of objectives related to the employee's area of responsibility.	Inspected the job position description for a sample of employment positions to determine that position descriptions were documented and included the expected behavior and skills needed to facilitate the accomplishment of objectives related to the employee's area of responsibility for each employment position sampled.	No exceptions noted.

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC1.5.3	Management conducts an annual company-wide strategy meeting to discuss and establish internal control responsibilities, performance measures and incentives with company business objectives.	Inspected the most recent company-wide strategy meeting agenda and calendar invitation to determine that management conducted an annual company-wide strategy meeting to discuss and establish internal control responsibilities, performance measures, and incentives with company business objectives during the period.	No exceptions noted.
CC1.5.4	New hires are required to acknowledge the employee handbook as a component of the onboarding process.	Inspected the employee handbook acknowledgment for a sample of employees hired during the period to determine that the employee handbook was acknowledged as a component of the onboarding process for each employee sampled.	No exceptions noted.
CC1.5.5	Management conducts a performance review of employees on an annual basis to evaluate performance of employees against expected levels of performance and conduct.	Inspected the most recent performance review documentation for a sample of current employees to determine that management conducted a performance review of employees during the period to evaluate performance of employees against expected levels of performance and conduct for each employee sampled.	No exceptions noted.
Communication and Information			
CC2.1 – COSO Principle 13: The entity obtains or generates and uses relevant, quality information to support the functioning of internal control.			
CC2.1.1	Organizational and information security policies and procedures are documented for supporting the functioning of controls and processes and made available to its personnel through the entity's shared network drives.	Inspected the data security policy to determine that organizational and information security policies and procedures were documented for supporting the functioning of controls and processes and made available to its personnel through the entity's shared network drives.	No exceptions noted.
CC2.1.2	Data flow diagrams, process flowcharts, narratives and procedures manuals are documented and maintained by management to identify the relevant internal and external information sources of the in-scope systems.	Inspected the network diagram to determine that data flow diagrams, process flowcharts, narratives and procedures manuals were documented and maintained by management to identify the relevant internal and external information sources of the in-scope systems.	No exceptions noted.
CC2.1.3	An inventory of system assets and components is maintained to classify and manage the information assets.	Inspected the inventory of system assets to determine that an inventory of system assets and components was maintained to classify and manage the information assets.	No exceptions noted.

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC2.1.4	Event logs record user activities, exceptions, faults, and information security events and are kept and regularly reviewed.	Inquired of the senior director of hosting operations regarding event log monitoring to determine that event logs recorded user activities, exceptions, faults, and information security events were kept and regularly reviewed.	No exceptions noted.
		Inspected the security information and event monitoring (SIEM) dashboard and an example e-mail alert generated during the period to determine that event logs recorded user activities, exceptions, faults, and information security events, and were kept and regularly reviewed during the period.	No exceptions noted.
CC2.1.5	The entity conducts vulnerability scans designed to identify potential vulnerabilities or misconfigurations on a weekly basis and engages a third-party vendor to perform internal penetration and external penetration testing on an annual basis. Vulnerabilities detected are triaged and monitored through resolution.	Inspected the vulnerability scan configurations and an example e-mail alert generated during the period to determine that the entity conducted vulnerability scans designed to identify potential vulnerabilities or misconfigurations on a weekly basis.	No exceptions noted.
		Inspected the most recent penetration test report and an example remediation ticket to determine that a that third-party vendor performed internal penetration and external penetration testing during the period and vulnerabilities detected were triaged and monitored through resolution.	No exceptions noted.
CC2.2 – COSO Principle 14: The entity internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control.			
CC2.2.1	Position descriptions are documented and include the expected behavior and skills needed to facilitate the accomplishment of objectives related to the employee's area of responsibility.	Inspected the job position description for a sample of employment positions to determine that position descriptions were documented and included the expected behavior and skills needed to facilitate the accomplishment of objectives related to the employee's area of responsibility for each employment position sampled.	No exceptions noted.

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC2.2.2	Anaqua's policies and procedures, code of conduct and employee handbook are made available to employees through the entity's shared network drives and e-mail communications.	Inspected the data security policy, code of conduct, and employee handbook to determine that the entity's data security policy, code of conduct, and employee handbook were made available to employees through Anaqua's shared network drives and e-mail communications.	No exceptions noted.
CC2.2.3	Personnel are required to acknowledge the employee handbook on an annual basis.	Inspected the employee handbook acknowledgment for a sample of current employees to determine that personnel were required to acknowledge the employee handbook during the period for each employee sampled.	No exceptions noted.
CC2.2.4	New hires are required to acknowledge the employee handbook as a component of the onboarding process.	Inspected the employee handbook acknowledgment for a sample of employees hired during the period to determine that the employee handbook was acknowledged as a component of the onboarding process for each employee sampled.	No exceptions noted.
CC2.2.5	Employees are provided security awareness training upon hire, and on an annual basis thereafter, to understand their obligations and responsibilities to comply with the entity's security policies.	Inquired of the senior director of hosting operations regarding security awareness training to determine that employees were provided security awareness training upon hire, and on an annual basis thereafter, to understand their obligations and responsibilities to comply with the entity's security policies.	No exceptions noted.
		Inspected the security awareness training program and documentation of completion for a sample of employees hired during the period to determine that security awareness training was provided to new employees upon hire to understand their obligations and responsibilities to comply with the entity's security policies for each employee sampled.	No exceptions noted.
		Inspected the security awareness training program and documentation of completion for a sample of current employees to determine that security awareness training was provided to employees during the period to understand their obligations and responsibilities to comply with the entity's security policies during the period for each employee sampled.	No exceptions noted.

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC2.2.6	Contractors are required to review and sign the data security policy upon hire and are required to attend the annual security awareness training on an annual basis thereafter, to understand their obligations and responsibilities to comply with the entity's security policies.	Inquired of the senior director of hosting operations regarding security awareness training to determine that contractors are required to review and sign the data security policy upon hire and are required to attend the annual security awareness training on an annual basis thereafter, to understand their obligations and responsibilities to comply with the entity's security policies.	No exceptions noted.
		Inspected the data security policy acknowledgment for a sample of contractors hired during the period to determine that contractors are required to review and sign the data security policy upon hire and are required to attend the annual security awareness training on an annual basis thereafter, to understand their obligations and responsibilities to comply with the entity's security policies.	No exceptions noted.
		Inspected the data security policy acknowledgement for a sample of current contractors to determine that contractors are required to review and sign the data security policy upon hire and are required to attend the annual security awareness training on an annual basis thereafter, to understand their obligations and responsibilities to comply with the entity's security policies.	No exceptions noted.
CC2.3 – COSO Principle 15: The entity communicates with external parties regarding matters affecting the functioning of internal control.			
CC2.3.1	Changes to commitments, requirements and responsibilities are communicated to third parties, external users, and customers via updated agreements, website notices, or mass notifications.	Inquired of the senior director of hosting operations regarding external party communications to determine that changes to commitments, requirements and responsibilities were communicated to third parties, external users, and customers via updated agreements, website notices, or mass notifications.	No exceptions noted.
		Inspected the support transition procedures to determine that changes to commitments, requirements and responsibilities were communicated to third parties, external users, and customers via updated agreements, website notices, or mass notifications.	No exceptions noted.

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC2.3.2	The entity's security commitments and the associated system requirements are documented in customer subscription agreements.	Inspected the signed master service agreements for a sample of customers onboarded during the period to determine that the entity's security commitments and the associated system requirements were documented in customer subscription agreements for each customer sampled.	No exceptions noted.
CC2.3.3	Documented escalation procedures for reporting failure incidents, concerns and other complaints are in place and shared with external parties.	Inspected the security event management policy to determine that documented escalation procedures for reporting failure incidents, concerns and other complaints were in place and shared with external parties.	No exceptions noted.
CC2.3.4	Signed nondisclosure agreements are required prior to sharing information designated as confidential with third parties.	Inquired of the senior director of hosting operations regarding nondisclosure agreements to determine that signed nondisclosure agreements were required prior to sharing information designated as confidential with third parties.	No exceptions noted.
		Inspected the signed master service agreements for a sample of customers onboarded during the period to determine that signed nondisclosure agreements were required prior to sharing information designated as confidential with third parties for each customer sampled.	No exceptions noted.
CC2.3.5	Release notes are communicated to customers by the product team.	Inspected the release note communications for a sample of application changes implemented during the period to determine that release notes were communicated to customers by the product team for each application release sampled.	No exceptions noted.
Risk Assessment			
CC3.1 – COSO Principle 6: The entity specifies objectives with sufficient clarity to enable the identification and assessment of risks relating to objectives.			
CC3.1.1	Anaqua establishes organizational strategies and objectives that are used to determine entity structure and performance metrics.	Inspected the information security management system (ISMS) metrics to determine that Anaqua established organizational strategies and objectives that were used to determine entity structure and performance metrics.	No exceptions noted.
CC3.1.2	Executive management has documented objectives that are SMART.	Inspected the ISMS manual to determine that executive management had documented objectives that were SMART.	No exceptions noted.

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC3.1.3	Executive management reviews policies, procedures, and other control documents for alignment to Anaqua's objectives on an annual basis.	Inspected the ISMC meeting minutes to determine that executive management reviewed policies, procedures, and other control documents for alignment to Anaqua's objectives during the period.	No exceptions noted.
CC3.1.4	Information security compliance audits are conducted by an accredited independent third-party assessor on an annual basis. The results of the audits are reviewed by management as part of the annual risk assessment process.	Inspected the most recent third-party audit reports and evidence of management review to determine that information security compliance audits were conducted by an accredited independent third-party assessor and the results of the audits were reviewed by management as part of the annual risk assessment process during the period.	No exceptions noted.
CC3.1.5	Management conducts an annual company-wide strategy meeting to discuss and establish internal control responsibilities, performance measures and incentives with company business objectives.	Inspected the most recent company-wide strategy meeting agenda and calendar invitation to determine that management conducted an annual company-wide strategy meeting to discuss and establish internal control responsibilities, performance measures, and incentives with company business objectives during the period.	No exceptions noted.
CC3.2 – COSO Principle 7: The entity identifies risks to the achievement of its objectives across the entity and analyzes risks as a basis for determining how the risks should be managed.			
CC3.2.1	Documented policies and procedures are in place to guide personnel when performing a risk assessment.	Inspected the information security risk management methodology policy to determine that documented policies and procedures were in place to guide personnel when performing a risk assessment.	No exceptions noted.
CC3.2.2	Management has defined a formal risk assessment process that specifies the process for identifying internal and external threats and vulnerabilities, evaluating, and addressing risks and defining specified risk tolerances.	Inspected the information security risk management methodology policy to determine that management had defined a formal risk assessment process that specified the process for identifying internal and external threats and vulnerabilities, evaluating, and addressing risks and defining specified risk tolerances.	No exceptions noted.
CC3.2.3	A formal risk assessment is performed on at least an annual basis to identify internal and external threats and vulnerabilities that could impair system commitments and requirements.	Inspected the results of the most recent risk assessment to determine that a formal risk assessment was performed during the period to identify internal and external threats and vulnerabilities that could impair system commitments and requirements.	No exceptions noted.

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC3.2.4	Identified risks are rated using a risk evaluation process and ratings are approved by management.	Inspected the information security risk management methodology policy and the results of the most recent risk assessment to determine that identified risks were rated using a risk evaluation process and ratings were approved by management.	No exceptions noted.
CC3.2.5	Identified fraud risks are reviewed and addressed using one of the following strategies: • Avoid the risk • Mitigate the risk • Transfer the risk • Accept the risk	Inspected the results of the most recent risk assessment and risk treatment plan to determine that risks identified as a part of the risk assessment process were addressed using one of the following strategies: • Avoid the risk • Mitigate the risk • Transfer the risk • Accept the risk	No exceptions noted.
CC3.3 – COSO Principle 8: The entity considers the potential for fraud in assessing risks to the achievement of objectives.			
CC3.3.1	Management identifies and assesses the types of fraud (e.g., fraudulent reporting, loss of assets, unauthorized system access, overriding controls) that could impact their business and operations on an annual basis.	Inspected the risk management methodology policy, the results of the most recent risk assessment, and the risk treatment plan to determine that management identified and assessed the types of fraud (e.g., fraudulent reporting, loss of assets, unauthorized system access, overriding controls) that could impact their business and operations during the period.	No exceptions noted.
CC3.3.2	Identified fraud risks are reviewed and addressed using one of the following strategies: • Avoid the risk • Mitigate the risk • Transfer the risk • Accept the risk	Inspected the risk treatment plan to determine that fraud risks identified were reviewed and addressed using one of the following strategies: • Avoid the risk • Mitigate the risk • Transfer the risk • Accept the risk	No exceptions noted.
CC3.3.3	As part of management's assessment of fraud risks, management considers key fraud factors such as incentives, pressures, opportunity for unauthorized access or use of data, and employee morale and attitude.	Inquired of the senior director of hosting operations regarding fraud risks to determine that as part of management's assessment of fraud risks, management considered key fraud factors such as incentives, pressures, opportunity for unauthorized access or use of data, and employee morale and attitude.	No exceptions noted.

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Inspected the risk management methodology to determine that as part of management's assessment of fraud risks, management considered key fraud factors such as incentives, pressures, opportunity for unauthorized access or use of data, and employee morale and attitude.	No exceptions noted.
CC3.4 – COSO Principle 9: The entity identifies and assesses changes that could significantly impact the system of internal control.			
CC3.4.1	Changes to the regulatory, economic, and physical environment in which the entity operates are considered and evaluated as part of the annual comprehensive risk assessment.	Inspected the risk management methodology policy and the results of the most recent risk assessment to determine that changes to the regulatory, economic, and physical environment in which the entity operates were considered and evaluated as part of the annual comprehensive risk assessment.	No exceptions noted.
CC3.4.2	Changes in key management and personnel are considered and evaluated as part of the annual comprehensive risk assessment.	Inspected the risk management methodology policy and the results of the most recent risk assessment to determine that changes in key management and personnel were considered and evaluated as part of the annual comprehensive risk assessment.	No exceptions noted.
CC3.4.3	Changes to the entity's systems, applications, technologies, and tools are considered and evaluated as part of the annual comprehensive risk assessment.	Inspected the risk management methodology policy and the results of the most recent risk assessment to determine that changes to the entity's systems, applications, technologies, and tools were considered and evaluated as part of the annual comprehensive risk assessment.	No exceptions noted.
CC3.4.4	Changes in vendor and third-party relationships are considered and evaluated as part of the annual comprehensive risk assessment.	Inspected the risk management methodology policy and the results of the most recent risk assessment to determine that changes in vendor and third-party relationships were considered and evaluated as part of the annual comprehensive risk assessment.	No exceptions noted.
Monitoring Activities			
CC4.1 – COSO Principle 16: The entity selects, develops, and performs ongoing and/or separate evaluations to ascertain whether the components of internal control are present and functioning.			
CC4.1.1	Executive management reviews policies, procedures, and other control documents for alignment to Anaqua's objectives on an annual basis.	Inspected the ISMC meeting minutes to determine that executive management reviewed policies, procedures, and other control documents for alignment to Anaqua's objectives during the period.	No exceptions noted.

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC4.1.2	Information security compliance audits are performed at least annually to demonstrate compliance with relevant laws, regulations, and standards.	Inspected the most recent internal audit report to determine that information security compliance audits were performed during the period to demonstrate compliance with relevant laws, regulations, and standards.	No exceptions noted.
CC4.1.3	Management obtains and reviews attestation reports from key vendors on an annual basis to evaluate the effectiveness of controls within the vendor or third party's environment.	Inquired of the senior director of hosting operations regarding third-party attestations to determine that management obtained and reviewed attestation reports from key vendors during the period to evaluate the effectiveness of controls within the vendor or third party's environment.	No exceptions noted.
		Inspected the vendor review documentation for a sample of key vendors to determine that management obtained and reviewed attestation reports from key vendors during the period to evaluate the effectiveness of controls within the vendor or third party's environment for each vendor sampled.	No exceptions noted.
CC4.2 – COSO Principle 17: The entity evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and the board of directors, as appropriate.			
CC4.2.1	Effectiveness of the internal controls implemented within the environment are evaluated annually.	Inspected the meeting minutes from the most recently conducted ISMC meeting to determine that effectiveness of the internal controls implemented within the environment were evaluated during the period.	No exceptions noted.
CC4.2.2	Information security compliance audits are conducted by an accredited independent third-party assessor on an annual basis. The results of the audits are reviewed by management as part of the annual risk assessment process.	Inspected the most recent third-party audit report and evidence of management review to determine that information security compliance audits were conducted by an accredited independent third-party assessor and the results of the audits were reviewed by management as part of the annual risk assessment process during the period.	No exceptions noted.
CC4.2.3	Controls within the environment are modified and implemented to mitigate vulnerabilities, deviations and control gaps identified as part of the various evaluations (e.g., risk assessments, vulnerability scans) performed.	Inspected the risk treatment plan to determine that controls within the environment were modified and implemented to mitigate vulnerabilities, deviations and control gaps identified as part of the various evaluations (e.g., risk assessments, vulnerability scans) performed.	No exceptions noted.

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
Control Activities			
CC5.1 – COSO Principle 10: The entity selects and develops control activities that contribute to the mitigation of risks to the achievement of objectives to acceptable levels.			
CC5.1.1	Controls within the environment are modified and implemented to mitigate vulnerabilities, deviations and control gaps identified as part of the various evaluations (e.g., risk assessments, vulnerability scans) performed.	Inspected the risk treatment plan to determine that controls within the environment were modified and implemented to mitigate vulnerabilities, deviations and control gaps identified as part of the various evaluations (e.g., risk assessments, vulnerability scans) performed.	No exceptions noted.
CC5.1.2	Performance of the internal controls implemented within the environment are assigned to process owners and operational personnel based on roles and responsibilities.	Inspected the risk management methodology policy, most recent risk assessment, and risk treatment plan to determine that performance of the internal controls implemented within the environment were assigned to process owners and operational personnel based on roles and responsibilities.	No exceptions noted.
CC5.1.3	Prior to the development and implementation of internal controls into the environment as part of the risk assessment, management considers the complexity, nature, and scope of its operations when developing control activities to mitigate the risks.	Inquired of the senior director of hosting operations regarding internal controls to determine that prior to the development and implementation of internal controls into the environment as part of the risk assessment, management considered the complexity, nature, and scope of its operations when developing control activities to mitigate the risks.	No exceptions noted.
		Inspected the results of the most recent risk assessment and risk treatment plan to determine that management considered the complexity, nature, and scope of its operations when developing control activities to mitigate the risks.	No exceptions noted.
CC5.1.4	Management develops risk mitigation strategies, including the implementation of controls, to address risks identified during the risk assessment process.	Inspected the risk treatment plan to determine that management developed risk mitigation strategies, including the implementation of controls, to address risks identified during the risk assessment process.	No exceptions noted.

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC5.2 – COSO Principle 11: The entity also selects and develops general control activities over technology to support the achievement of objectives.			
CC5.2.1	The internal controls implemented around Anaqua's technology infrastructure include, but are not limited to: - Restricting access rights to authorized users - Limiting services to what is required for business operations - Authentication of access - Protecting the entity's assets from external threats	Inspected the data security policy to determine that internal controls implemented around Anaqua's technology infrastructure included, but were not limited to: - Restricting access rights to authorized users - Limiting services to what is required for business operations - Authentication of access - Protecting the entity's assets from external threats	No exceptions noted.
CC5.2.2	Assigned risk owners select and develop control activities over technology to support the achievement of objectives as an output from the risk assessment performed on an annual basis. The control activities are documented within the mitigation plans that are created by the risk owners for risks above the tolerable threshold.	Inspected the risk treatment plan to determine that assigned risk owners selected and developed control activities over technology to support the achievement of objectives as an output from the risk assessment performed and that the control activities were documented within the mitigation plans that were created by the risk owners for risks above a tolerable threshold during the period.	No exceptions noted.
CC5.3 – COSO Principle 12: The entity deploys control activities through policies that establish what is expected and in procedures that put policies into action.			
CC5.3.1	Organizational and information security policies and procedures are documented for supporting the functioning of controls and processes and made available to its personnel through the entity's shared network drives.	Inspected the data security policy to determine that organizational and information security policies and procedures were documented for supporting the functioning of controls and processes and made available to its personnel through the entity's shared network drives.	No exceptions noted.
CC5.3.2	Position descriptions are documented and include the expected behavior and skills needed to facilitate the accomplishment of objectives related to the employee's area of responsibility.	Inspected the job position description for a sample of employment positions to determine that position descriptions were documented and included the expected behavior and skills needed to facilitate the accomplishment of objectives related to the employee's area of responsibility for each employment position sampled.	No exceptions noted.
CC5.3.3	Effectiveness of the internal controls implemented within the environment are evaluated annually.	Inspected the meeting minutes from the most recently conducted ISMC meeting to determine that effectiveness of the internal controls implemented within the environment were evaluated during the period.	No exceptions noted.

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC5.3.4	The employee handbook and code of conduct addresses remedial actions for lack of compliance with policies and procedures.	Inspected the employee handbook and code of conduct to determine that the employee handbook and code of conduct addressed remedial actions for lack of compliance with policies and procedures.	No exceptions noted.
Logical and Physical Access Controls			
CC6.1 – The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.			
CC6.1.1	An inventory of system assets and components is maintained to classify and manage the information assets.	Inspected the inventory of system assets to determine that an inventory of system assets and components was maintained to classify and manage the information assets.	No exceptions noted.
CC6.1.2	Documented security policies and procedures are in place that include, but are not limited to, the following areas: • System settings • Authentication • Access control • Security monitoring • Password protection	Inspected the security policy and procedures to determine that documented security policies and procedures were in place that included, but were not limited to, the following areas: • System settings • Authentication • Access control • Security monitoring • Password protection	No exceptions noted.
CC6.1.3	The following in-scope systems are configured to authenticate users with a unique user account and enforce minimum password requirements: • Network domain • Server operating system • Database systems • AQX Corporate, AQX Law Firm, PATTSY WAVE, Lecorpio, and ideaPoint Innovation Management applications • VPN • IBM cloud management console • Azure cloud management console	Inspected the production network domain authentication configurations and a system-generated listing of user accounts to determine that the production network domain was configured to authenticate users with a unique user account and enforce minimum password requirements.	No exceptions noted.
		Inspected the operating system authentication configurations and system-generated listing of user accounts for a sample of production servers to determine that servers were configured to authenticate users with a unique user account and enforced minimum password requirements for each production server sampled.	No exceptions noted.

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Inspected the database authentication configurations and system-generated listing of user accounts for a sample of production databases to determine that databases were configured to authenticate users with a unique user account and enforced minimum password requirements for each production database sampled.	No exceptions noted.
		Inspected the application authentication configurations and system-generated listing of user accounts for the in-scope applications to determine that the following applications were configured to authenticate users with a unique user account and enforced minimum password requirements: • AQX Corporate & Law Firm • PATTSY WAVE • Lecorpio • ideaPoint Innovation Management	No exceptions noted.
		Inspected the production VPN authentication configurations and system-generated listing of user accounts to determine that the VPN was configured to authenticate users with a unique user account and enforced minimum password requirements.	No exceptions noted.
		Inspected the IBM Cloud Management Console authentication configurations and system-generated listing of user accounts to determine that the IBM Cloud Console was configured to authenticate users with a unique user account and enforced minimum password requirements.	No exceptions noted.
		Inspected the Azure Cloud Management Console authentication configurations and a system-generated listing of user accounts to determine that the Azure Cloud Management Console was configured to authenticate users with a unique user account and enforced minimum password requirements.	No exceptions noted.

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC6.1.4	Remote access to the production network requires 2FA utilizing a token and passcode.	Inspected the remote access authentication configurations to determine that remote access to the production network required 2FA utilizing a token and passcode.	No exceptions noted.
CC6.1.5	Privileged access to the following in-scope systems is restricted to authorized personnel: • Network domain • Server operating system • Database systems • AQX Corporate, AQX Law Firm, PATTSY WAVE, Lecorpio, and ideaPoint Innovation Management applications • VPN • IBM cloud management console • Azure cloud management console	Inspected the system-generated listing of user accounts with administrative access to the production network domain with the assistance of the senior director of hosting operations to determine that privileged access to the network domain was restricted to authorized personnel.	No exceptions noted.
		Inspected the system-generated listing of user accounts with administrative access to the operating system for a sample of production servers with the assistance of the senior director of hosting operations to determine that each production server sampled was restricted to authorized personnel.	No exceptions noted.
		Inspected the system-generated listing of user accounts with administrative access to the database systems for a sample of production databases with the assistance of the senior director of hosting operations to determine that each production database sampled was restricted to user accounts accessible by authorized personnel.	No exceptions noted.
		Inspected the system-generated listing of user accounts with administrative access to the applications with the assistance of the senior director of hosting operations to determine that privileged access to the following applications were restricted to authorized personnel: • AQX Corporate & Law Firm • PATTSY WAVE • Lecorpio • ideaPoint Innovation Management	No exceptions noted.
		Inspected the system-generated listing of user accounts with administrative access to the VPN with the assistance of the senior director of hosting operations to determine that privileged access to the VPN was restricted to authorized personnel.	No exceptions noted.

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Inspected the system-generated listing of user accounts with administrative access to the IBM Cloud Management Console with the assistance of the senior director of hosting operations to determine that privileged access to the IBM Cloud Management Console was restricted to authorized personnel.	No exceptions noted.
		Inspected the system-generated listing of user accounts with administrative access to the Azure Cloud Management Console with the assistance of the senior director of hosting operations to determine that privileged access to the Azure Cloud Management Console was restricted to authorized personnel.	No exceptions noted.
	IBM and Microsoft Azure are responsible for managing logical access to the underlying network, virtualization management, and storage devices for their cloud hosting services where the IBM and Microsoft Azure hosted production applications reside.		
CC6.2 – Prior to issuing system credentials and granting system access, the entity registers and authorizes new internal and external users whose access is administered by the entity. For those users whose access is administered by the entity, user system credentials are removed when user access is no longer authorized.			
CC6.2.1	Documented security policies and procedures are in place that include, but are not limited to, the following areas: • System settings • Authentication • Access control • Security monitoring • Password protection	Inspected the security policy and procedures to determine that documented security policies and procedures were in place that included, but were not limited to, the following areas: • System settings • Authentication • Access control • Security monitoring • Password protection	No exceptions noted.
CC6.2.2	Logical access to the in-scope systems is approved prior to granting access as a component of the onboarding process.	Inquired of the senior director of hosting operations regarding the access approval process to determine that logical access to the in-scope systems was approved prior to granting access as a component of the onboarding process.	No exceptions noted.
		Inspected the access request ticket for a sample of employees hired during the period to determine that logical access to the in-scope systems was approved prior to granting access as a component of the onboarding process for each employee sampled.	No exceptions noted.

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC6.2.3	Logical access to the following in-scope systems is revoked as a component of the termination process: • Network domain • Server operating system • Database systems • AQX Corporate, AQX Law Firm, PATTSY WAVE, Lecorpio, and ideaPoint Innovation Management applications • VPN • IBM cloud management console • Azure cloud management console	Inspected the termination tickets for a sample of employees terminated during the period to determine that logical access to the following in-scope systems was revoked as a component of the termination process for each terminated employee sampled: • Network domain • Server operating system • Database systems • AQX Corporate, AQX Law Firm, PATTSY WAVE, Lecorpio, and ideaPoint Innovation Management applications • VPN • IBM cloud management console • Azure cloud management console	No exceptions noted.
		Inspected the system-generated listings of users for a sample of employees terminated during the period and for a sample of in-scope systems to determine that logical access to the following in-scope systems was revoked as a component of the termination process for each terminated employee sampled: • Network domain • Server operating system • Database systems • AQX Corporate, AQX Law Firm, PATTSY WAVE, Lecorpio, and ideaPoint Innovation Management applications • VPN • IBM cloud management console • Azure cloud management console	No exceptions noted.
CC6.2.4	Access reviews of the production network are completed by management on at least an annual basis.	Inspected the results of the most recent production network access review to determine that access reviews of the production network were completed by management during the period.	No exceptions noted.
	IBM and Microsoft Azure are responsible for managing logical access to the underlying network, virtualization management, and storage devices for their cloud hosting services where the IBM and Microsoft Azure hosted production applications reside.		

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC6.3 – The entity authorizes, modifies, or removes access to data, software, functions, and other protected information assets based on roles, responsibilities, or the system design and changes, giving consideration to the concepts of least privilege and segregation of duties, to meet the entity's objectives.			
CC6.3.1	Documented security policies and procedures are in place that include, but are not limited to, the following areas: • System settings • Authentication • Access control • Security monitoring • Password protection	Inspected the security policy and procedures to determine that documented security policies and procedures were in place that included, but were not limited to, the following areas: • System settings • Authentication • Access control • Security monitoring • Password protection	No exceptions noted.
CC6.3.2	Logical access to the in-scope systems is approved prior to granting access as a component of the onboarding process.	Inquired of the senior director of hosting operations regarding the access approval process to determine that logical access to the in-scope systems was approved prior to granting access as a component of the onboarding process.	No exceptions noted.
		Inspected the access request ticket for a sample of employees hired during the period to determine that logical access to the in-scope systems was approved prior to granting access as a component of the onboarding process for each employee sampled.	No exceptions noted.
CC6.3.3	Logical access to the following in-scope systems is revoked as a component of the termination process: • Network domain • Server operating system • Database systems • AQX Corporate, AQX Law Firm, PATTSY WAVE, Lecorpio, and ideaPoint Innovation Management applications • VPN • IBM cloud management console • Azure cloud management console	Inspected the termination tickets for a sample of employees terminated during the period to determine that logical access to the following in-scope systems was revoked as a component of the termination process for each terminated employee sampled: • Network domain • Server operating system • Database systems • AQX Corporate, AQX Law Firm, PATTSY WAVE, Lecorpio, and ideaPoint Innovation Management applications • VPN • IBM cloud management console • Azure cloud management console	No exceptions noted.

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Inspected the system-generated listings of users with access to in-scope systems for a sample of employees terminated during the period and for a sample of in-scope systems to determine that logical access to the following in-scope systems was revoked as a component of the termination process for each terminated employee sampled: • Network domain • Server operating system • Database systems • AQX Corporate, AQX Law Firm, PATTSY WAVE, Lecorpio, and ideaPoint Innovation Management applications • VPN • IBM cloud management console • Azure cloud management console	No exceptions noted.
CC6.3.4	Access reviews of the production network are completed by management on at least an annual basis.	Inspected the system-generated listing of user accounts with administrative access to the production network domain with the assistance of the senior director of hosting operations to determine that privileged access to the network domain was restricted to authorized personnel.	No exceptions noted.
CC6.3.5	Privileged access to the following in-scope systems is restricted to authorized personnel: • Network domain • Server operating system • Database systems • AQX Corporate, AQX Law Firm, PATTSY WAVE, Lecorpio, and ideaPoint Innovation Management applications • VPN • IBM cloud management console • Azure cloud management console	Inspected the system-generated listing of user accounts with administrative access to the production network domain with the assistance of the senior director of hosting operations to determine that privileged access to the network domain was restricted to authorized personnel.	No exceptions noted.
		Inspected the system-generated listing of user accounts with administrative access to the server operating system for a sample of production servers with the assistance of the senior director of hosting operations to determine that each production server sampled was restricted to authorized personnel.	No exceptions noted.

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Inspected the system-generated listing of user accounts with administrative access to the database systems for a sample of production databases with the assistance of the senior director of hosting operations to determine that each production database sampled was restricted to user accounts accessible by authorized personnel.	No exceptions noted.
		Inspected the system-generated listing of user accounts with administrative access to the applications with the assistance of the senior director of hosting operations to determine that privileged access to the following applications were restricted to authorized personnel: • AQX Corporate & Law Firm • PATTSY WAVE • Lecorpio • ideaPoint Innovation Management	No exceptions noted.
		Inspected the system-generated listing of user accounts with administrative access to the VPN with the assistance of the senior director of hosting operations to determine that privileged access to the VPN was restricted to authorized personnel.	No exceptions noted.
		Inspected the system-generated listing of user accounts with administrative access to the IBM Cloud Management Console with the assistance of the senior director of hosting operations to determine that privileged access to the IBM Cloud Management Console was restricted to authorized personnel.	No exceptions noted.
		Inspected the system-generated listing of user accounts with administrative access to the Azure Cloud Management Console with the assistance of the senior director of hosting operations to determine that privileged access to the Azure Cloud Management Console was restricted to authorized personnel.	No exceptions noted.

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC6.4 – The entity restricts physical access to facilities and protected information assets (for example, data center facilities, backup media storage, and other sensitive locations) to authorized personnel to meet the entity's objectives.			
	IBM and Microsoft Azure are responsible for restricting physical access to data center facilities, backup media, and other system components including firewalls, routers, and servers for IBM and Microsoft Azure hosted applications.		
CC6.5 – The entity discontinues logical and physical protections over physical assets only after the ability to read or recover data and software from those assets has been diminished and is no longer required to meet the entity's objectives.			
CC6.5.1	Media handling and disposal procedures are in place to guide personnel in performing sanitization procedures on instances where production data resides to help ensure data and software is unrecoverable prior to retiring the virtual asset.	Inspected the media handling policy to determine that media handling and disposal procedures were in place to guide personnel in performing sanitization procedures on instances where production data resides to help ensure data and software was unrecoverable prior to retiring the virtual asset.	No exceptions noted.
	IBM and Microsoft Azure are responsible for managing logical access to the underlying network, virtualization management, and storage devices for their cloud hosting services where the IBM and Microsoft Azure hosted production applications reside.		
	IBM and Microsoft Azure are responsible for restricting physical access to data center facilities, backup media, and other system components including firewalls, routers, and servers for IBM and Microsoft Azure hosted applications.		
CC6.6 – The entity implements logical access security measures to protect against threats from sources outside its system boundaries.			
CC6.6.1	A firewall is in place to filter unauthorized inbound network traffic from the internet.	Inspected the firewall rulesets to determine that a firewall was in place to filter unauthorized inbound network traffic from the internet.	No exceptions noted.
CC6.6.2	Groups of information services, users, and information systems are segregated on networks.	Inspected the network diagram and a system-generated listing of customer databases to determine that groups of information services, users, and information systems were segregated on networks.	No exceptions noted.
CC6.6.3	Remote access to the production network requires 2FA utilizing a token and passcode.	Inspected the remote access authentication configurations to determine that remote access to the production network required 2FA utilizing a token and passcode.	No exceptions noted.
CC6.6.4	An encrypted VPN is required for remote access to the production environment to help ensure the security and integrity of the data passing over the public network.	Inspected the VPN encryption configurations to determine that an encrypted VPN was required for remote access to the production environment to help ensure the security and integrity of the data passing over the public network.	No exceptions noted.

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC6.6.5	Web communication sessions are secured via TLS encryption.	Inspected the web server TLS encryption configurations to determine that web communication sessions were secured via TLS encryption.	No exceptions noted.
CC6.6.6	The entity conducts vulnerability scans designed to identify potential vulnerabilities or misconfigurations on a weekly basis and engages a third-party vendor to perform internal penetration and external penetration testing on an annual basis. Vulnerabilities detected are triaged and monitored through resolution.	Inspected the vulnerability scan configurations and an example e-mail alert generated during the period to determine that the entity conducted vulnerability scans designed to identify potential vulnerabilities or misconfigurations on a weekly basis.	No exceptions noted.
		Inspected the most recent penetration test report and an example remediation ticket to determine that a third-party vendor performed internal penetration and external penetration testing during the period and vulnerabilities detected were triaged and monitored through resolution.	No exceptions noted.
CC6.6.7	A SIEM tool is utilized to collect log data from system resources and alert IT personnel when certain predefined rules are exceeded.	Inspected the SIEM tool dashboard, notification configurations, and an example alert generated during the period to determine that a SIEM tool was utilized to collect log data from system resources and alert IT personnel when certain predefined rules were exceeded.	No exceptions noted.
IBM and Microsoft Azure are responsible for managing logical access to the underlying network, virtualization management, and storage devices for their cloud hosting services where the IBM and Microsoft Azure hosted production applications reside.			
CC6.7 – The entity restricts the transmission, movement, and removal of information to authorized internal and external users and processes, and protects it during transmission, movement, or removal to meet the entity's objectives.			
CC6.7.1	Web communication sessions are secured via TLS encryption.	Inspected the web server TLS encryption configurations to determine that web communication sessions were secured via TLS encryption.	No exceptions noted.
CC6.7.2	Encryption technologies or secured communication channels are used to protect transmission of data and other communications beyond connectivity access points.	Inspected the VPN encryption configurations, web server encryption configurations, and firewall rulesets to determine that encryption technologies or secured communication channels were used to protect transmission of data and other communications beyond connectivity access points.	No exceptions noted.

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC6.7.3	A policy is in place to guide personnel on the use and protection of cryptographic keys to protect the confidentiality, authenticity, and/or integrity of information.	Inspected the encryption policy to determine that a policy was in place to guide personnel on the use and protection of cryptographic keys to protect the confidentiality, authenticity, and/or integrity of information.	No exceptions noted.
	IBM and Microsoft Azure are responsible for managing logical access to the underlying network, virtualization management, and storage devices for their cloud hosting services where the IBM and Microsoft Azure hosted production applications reside.		
CC6.8 – The entity implements controls to prevent or detect and act upon the introduction of unauthorized or malicious software to meet the entity’s objectives.			
CC6.8.1	A management-defined change control process is used for the implementation of software.	Inspected the change management policy to determine that a management-defined change control process was used for the implementation of software.	No exceptions noted.
CC6.8.2	Antivirus software is installed on production systems to detect and prevent the transmission of data or files that contain certain virus signatures recognized by the antivirus software.	Inspected the antivirus software dashboard and the registered asset listing to determine that antivirus software was installed on production systems to detect and prevent the transmission of data or files that contain certain virus signatures recognized by the antivirus software.	No exceptions noted.
		Inspected the antivirus software configurations for a sample of production servers to determine that antivirus software was installed on production systems for each production server sampled.	No exceptions noted.
CC6.8.3	The entity conducts vulnerability scans designed to identify potential vulnerabilities or misconfigurations on a weekly basis and engages a third-party vendor to perform internal penetration and external penetration testing on an annual basis. Vulnerabilities detected are triaged and monitored through resolution.	Inspected the vulnerability scan configurations and an example e-mail alert generated during the period to determine that the entity conducted vulnerability scans designed to identify potential vulnerabilities or misconfigurations on a weekly basis.	No exceptions noted.
		Inspected the most recent penetration test report and an example remediation ticket to determine that a that third-party vendor performed internal penetration and external penetration testing during the period and vulnerabilities detected were triaged and monitored through resolution.	No exceptions noted.

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
System Operations			
CC7.1 – To meet its objectives, the entity uses detection and monitoring procedures to identify (1) changes to configurations that result in the introduction of new vulnerabilities, and (2) susceptibilities to newly discovered vulnerabilities.			
CC7.1.1	Monitoring software is used to identify and evaluate ongoing system security threats, changing resource utilization needs and unusual system activity.	Inspected the monitoring software dashboard to determine that monitoring software was used to identify and evaluate ongoing system security threats, changing resource utilization needs, and unusual system activity.	No exceptions noted.
CC7.1.2	The entity conducts vulnerability scans designed to identify potential vulnerabilities or misconfigurations on a weekly basis and engages a third-party vendor to perform internal penetration and external penetration testing on an annual basis. Vulnerabilities detected are triaged and monitored through resolution.	Inspected the vulnerability scan configurations and an example e-mail alert generated during the period to determine that the entity conducted vulnerability scans designed to identify potential vulnerabilities or misconfigurations on a weekly basis.	No exceptions noted.
		Inspected the most recent penetration test report and an example remediation ticket to determine that a that third-party vendor performed internal penetration and external penetration testing during the period and vulnerabilities detected were triaged and monitored through resolution.	No exceptions noted.
	IBM and Microsoft Azure are responsible for restricting physical access to data center facilities, backup media, and other system components including firewalls, routers, and servers for IBM and Microsoft Azure hosted applications.		
CC7.2 – The entity monitors system components and the operation of those components for anomalies that are indicative of malicious acts, natural disasters, and errors affecting the entity's ability to meet its objectives; anomalies are analyzed to determine whether they represent security events.			
CC7.2.1	Event logs record user activities, exceptions, faults, and information security events and are kept and regularly reviewed.	Inquired of the senior director of hosting operations regarding event log monitoring to determine that event logs recorded user activities, exceptions, faults, and information security events were kept and regularly reviewed.	No exceptions noted.
		Inspected the SIEM dashboard and an example e-mail alert generated during the period to determine that event logs recorded user activities, exceptions, faults, and information security events.	No exceptions noted.
CC7.2.2	Monitoring software is used to identify and evaluate ongoing system security threats, changing resource utilization needs and unusual system activity.	Inspected the monitoring software dashboard to determine that monitoring software was used to identify and evaluate ongoing system security threats, changing resource utilization needs, and unusual system activity.	No exceptions noted.

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC7.2.3	Procedures are in place for responding to security incidents and effectiveness of those policies and procedures are evaluated on an annual basis.	Inspected the security event management policy and evidence of management review to determine that procedures were in place for responding to security incidents and the effectiveness of those policies and procedures were evaluated during the period.	No exceptions noted.
CC7.2.4	Information security events are reported to the help desk and tracked through resolution.	Inspected the security event ticket documentation for a sample of security events during the period to determine that information security events were reported to the help desk and tracked through resolution for each security event sampled.	No exceptions noted.
CC7.2.5	The entity conducts vulnerability scans designed to identify potential vulnerabilities or misconfigurations on a weekly basis and engages a third-party vendor to perform internal penetration and external penetration testing on an annual basis. Vulnerabilities detected are triaged and monitored through resolution.	Inspected the vulnerability scan configurations and an example e-mail alert generated during the period to determine that the entity conducted vulnerability scans designed to identify potential vulnerabilities or misconfigurations on a weekly basis.	No exceptions noted.
		Inspected the most recent penetration test report and an example remediation ticket to determine that a third-party vendor performed internal penetration and external penetration testing during the period and vulnerabilities detected were triaged and monitored through resolution.	No exceptions noted.
CC7.2.6	Antivirus software is installed on production systems to detect and prevent the transmission of data or files that contain certain virus signatures recognized by the antivirus software.	Inspected the antivirus software dashboard and the registered asset listing to determine that antivirus software was installed on production systems to detect and prevent the transmission of data or files that contain certain virus signatures recognized by the antivirus software.	No exceptions noted.
		Inspected the antivirus software configurations for a sample of production servers to determine that antivirus software was installed on production systems for each production server sampled.	No exceptions noted.
	IBM and Microsoft Azure are responsible for monitoring any changes to the logical access controls systems for the underlying network, virtualization management, and storage devices where the IBM and Microsoft Azure hosted production applications reside.		
	IBM and Microsoft Azure are responsible for restricting physical access to data center facilities, backup media, and other system components including firewalls, routers, and servers for IBM and Microsoft Azure hosted applications.		

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC7.3 – The entity evaluates security events to determine whether they could or have resulted in a failure of the entity to meet its objectives (security incidents) and, if so, takes actions to prevent or address such failures.			
CC7.3.1	Procedures are in place for documenting, escalating, resolving, and taking actions to prevent or address security incidents.	Inspected the security event management policy to determine that procedures were in place for documenting, escalating, resolving, and taking actions to prevent or address security incidents.	No exceptions noted.
CC7.3.2	Incident response procedures are in place that outline the roles and responsibilities of management when responding to a security incident.	Inspected the security event management policy to determine that management responsibilities and procedures were established to ensure a quick, effective, and orderly response to information security incidents.	No exceptions noted.
CC7.3.3	Information security events are reported to the help desk and tracked through resolution.	Inspected the security event ticket documentation for a sample of security events during the period to determine that information security events were reported to the help desk and tracked through resolution for each security event sampled.	No exceptions noted.
CC7.4 - The entity responds to identified security incidents by executing a defined incident-response program to understand, contain, remediate, and communicate security incidents, as appropriate.			
CC7.4.1	Incident response procedures are in place that outline the roles and responsibilities of management when responding to a security incident.	Inspected the security event management policy to determine that management responsibilities and procedures were established to ensure a quick, effective, and orderly response to information security incidents.	No exceptions noted.
CC7.4.2	Procedures are in place to contain security incidents that actively threaten entity objectives.	Inspected the security event management policy to determine that procedures were in place to contain security incidents that actively threaten entity objectives.	No exceptions noted.
CC7.4.3	Information security events are reported to the help desk and tracked through resolution.	Inspected the security event ticket documentation for a sample of security events during the period to determine that information security events were reported to the help desk and tracked through resolution for each security event sampled.	No exceptions noted.
CC7.5 – The entity identifies, develops, and implements activities to recover from identified security incidents.			
CC7.5.1	Procedures are in place for responding to security incidents and effectiveness of those policies and procedures are evaluated on an annual basis.	Inspected the security event management policy and evidence of management review to determine that procedures were in place for responding to security incidents and the effectiveness of those policies and procedures were evaluated during the period.	No exceptions noted.

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC7.5.2	The organization shall establish, document, implement and maintain processes, procedures, and controls to ensure the required level of continuity for information security during an adverse situation.	Inspected the disaster recovery and business continuity plan to determine that the organization had established, documented, implemented, and maintained processes, procedures, and controls to ensure the required level of continuity for information security during an adverse situation.	No exceptions noted.
CC7.5.3	Information security events are reported to the help desk and tracked through resolution.	Inspected the security event ticket documentation for a sample of security events during the period to determine that information security events were reported to the help desk and tracked through resolution for each security event sampled.	No exceptions noted.
Change Management			
CC8.1 – The entity authorizes, designs, develops or acquires, configures, documents, tests, approves, and implements changes to infrastructure, data, software, and procedures to meet its objectives.			
CC8.1.1	Change management policies and procedures are in place to guide personnel in change management procedures through the change lifecycle.	Inspected the change management policies and procedures to determine that change management policies and procedures were in place to guide personnel in change management procedures through the change lifecycle.	No exceptions noted.
CC8.1.2	The application development and testing environments are logically separated from the production environment.	Inspected the development, test, and production environment configurations to determine that the application development and test environments were logically separated from the production environment.	No exceptions noted.
CC8.1.3	A change ticketing system is in place to document, manage, and monitor change requests through implementation.	Inspected the change documentation for a sample of application changes implemented during the period to determine that a change management ticketing system was in place to document, manage, and monitor change requests through implementation for each application release sampled.	No exceptions noted.
CC8.1.4	Infrastructure changes are documented in a ticketing system and require approval from IT management.	Inspected the change documentation for a sample of infrastructure changes implemented during the period to determine that infrastructure changes were documented in a ticketing system and approved by IT management for each infrastructure change sampled.	No exceptions noted.

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC8.1.5	Changes made to in-scope systems are authorized, tested, and approved prior to implementation.	Inspected the change documentation for a sample of application changes implemented during the period to determine that changes made to in-scope systems were authorized, tested, and approved prior to implementation for each application release sampled.	No exceptions noted.
CC8.1.6	Management personnel require customer change requests to be initiated by the customer via the change management ticketing system.	Inspected the customer change request documentation for a sample of customer change requests implemented during the period to determine that management personnel required customer change requests to be initiated by the customer via the change management ticketing system for each customer change request sampled.	No exceptions noted.
CC8.1.7	The ability to modify source code within the version control software is restricted to user accounts accessible by authorized personnel.	Inspected the system-generated listing of user accounts with the ability to modify source code within the version control software with the assistance of the senior director of hosting operations to determine that the ability to modify source code within the version control software was restricted to user accounts accessible by authorized personnel.	No exceptions noted.
CC8.1.8	The ability to implement changes is restricted to user accounts accessible by authorized personnel.	Inspected the system-generated listing of user accounts with ability to implement changes into the production environment with the assistance of the senior director of hosting operations to determine that the ability to implement changes was restricted to user accounts accessible by authorized personnel.	No exceptions noted.
CC8.1.9	A code review scan is performed to detect vulnerabilities for each application release.	Inspected the application vulnerability scan report for a sample of application changes implemented during the period to determine that a code review scan was performed to detect vulnerabilities for each application release sampled.	No exceptions noted.

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
Risk Mitigation			
CC9.1 – The entity identifies, selects, and develops risk mitigation activities for risks arising from potential business disruptions.			
CC9.1.1	Documented policies and procedures are in place to guide personnel in identifying, selecting, and developing risk management strategies specifically addressing the risks arising from potential business disruptions when performing a risk assessment.	Inspected the risk management methodology policy to determine that documented policies and procedures were in place to guide personnel in identifying, selecting, and developing risk management strategies specifically addressing the risks arising from potential business disruptions when performing a risk assessment.	No exceptions noted.
CC9.1.2	The risk management program includes the use of insurance to minimize the financial impact of loss events that would otherwise impair the ability of the entity to meet its objectives.	Inspected the cybersecurity insurance policy to determine that the risk management program included the use of insurance to minimize the financial impact of loss events that would otherwise impair the ability of the entity to meet its objectives.	No exceptions noted.
CC9.1.3	A business continuity/disaster recovery plan is in place, reviewed and tested on an annual basis.	Inspected the business continuity/disaster recovery plan and most recently completed disaster recovery test results to determine that a business continuity/disaster recovery plan was in place, reviewed and tested during the period.	No exceptions noted.
CC9.2 – The entity assesses and manages risks associated with vendors and business partners.			
CC9.2.1	A supplier management policy is in place that address the following: • New supplier acceptance criteria • New suppliers review and acceptance • Existing suppliers review	Inspected the supplier security policy to determine that a supplier management policy was in place that addressed the following: • New supplier acceptance criteria • New suppliers review and acceptance • Existing suppliers review	No exceptions noted.
CC9.2.2	Signed vendor agreements are in place prior to engaging with third-party vendors.	Inspected the vendor management tool with the assistance of the director of hosting operations and determined that there were no vendors onboarded during the period; therefore, no testing of operating effectiveness was performed.	
CC9.2.3	Signed nondisclosure agreements are required prior to sharing information designated as confidential with third parties.	Inquired of the senior director of hosting operations regarding nondisclosure agreements to determine that signed nondisclosure agreements were required prior to sharing information designated as confidential with third parties.	No exceptions noted.

Control #	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Inspected the signed master service agreements for a sample of customers onboarded during the period to determine that signed nondisclosure agreements were required prior to sharing information designated as confidential with third parties for each customer sampled.	No exceptions noted.
CC9.2.4	Management obtains and reviews attestation reports from key vendors on an annual basis to evaluate the effectiveness of controls within the vendor or third party's environment.	Inquired of the senior director of hosting operations regarding third-party attestations to determine that management obtained and reviewed attestation reports from key vendors during the period to evaluate the effectiveness of controls within the vendor or third party's environment.	No exceptions noted.
		Inspected the vendor review documentation for a sample of key vendors to determine that management obtained and reviewed attestation reports from key vendors during the period to evaluate the effectiveness of controls within the vendor or third party's environment for each vendor sampled.	No exceptions noted.
CC9.2.5	The risk management program includes the use of insurance to minimize the financial impact of loss events that would otherwise impair the ability of the entity to meet its objectives.	Inspected the cybersecurity insurance policy to determine that the risk management program included the use of insurance to minimize the financial impact of loss events that would otherwise impair the ability of the entity to meet its objectives.	No exceptions noted.